



مصرف الإمارات العربية المتحدة المركزي
CENTRAL BANK OF THE U.A.E.

نظام إدارة المخاطر التشغيلية Operational Risk Management Regulation

المحتويات CONTENTS				
Subject		الصفحة Page	الموضوع	
Introduction		3	مقدمة	
Scope		3	النطاق	
Objective		3	الهدف	
Article (1)	Definitions	4	تعريفات	المادة (1)
Article (2)	Operational Risk Management Framework	8	إطار إدارة المخاطر التشغيلية	المادة (2)
Article (3)	Operational Resilience	10	المرونة التشغيلية	المادة (3)
Article (4)	Role of the Board of Directors	12	دور مجلس الإدارة	المادة (4)
Article (5)	Role of Senior Management	14	دور الإدارة العليا	المادة (5)
Article (6)	Operational Risk Management Function	16	وظيفة إدارة المخاطر التشغيلية	المادة (6)
Article (7)	Internal Control System	17	نظام الضبط الداخلي	المادة (7)
Article (8)	ICT and Cybersecurity Management	21	إدارة تقنية المعلومات والاتصال والأمن السيبراني	المادة (8)
Article (9)	Incident Management	24	إدارة الحوادث	المادة (9)
Article (10)	Risk Data and Systems	26	بيانات ونظم المخاطر	المادة (10)
Article (11)	Business Continuity Planning	27	تخطيط استمرارية الأعمال	المادة (11)
Article (12)	Change Management and Changes in Operations	29	إدارة التغيير والتغييرات في العمليات	المادة (12)
Article (13)	Third Party Risk Management	32	إدارة مخاطر مزودي الخدمات الخارجيين	المادة (13)
Article (14)	Shari'ah Non-Compliance Risk	34	مخاطر عدم الامتثال لأحكام الشريعة	المادة (14)
Article (15)	Notification and Reporting Requirements	36	متطلبات الإبلاغ ورفع التقارير	المادة (15)
Article (16)	Disclosure Requirements	37	متطلبات الإفصاح	المادة (16)
Article (17)	Enforcement & Sanctions	38	الإنفاذ والعقوبات	المادة (17)
Article (18)	Interpretation of Regulation	39	تفسير النظام	المادة (18)
Article (19)	Cancellation of Previous Notices	39	إلغاء إشعارات سابقة	المادة (19)
Article (20)	Publication & Effective Date	39	النشر وتاريخ النفاذ	المادة (20)
	Annex 1	40	الملحق 1	

Circular No.: 1/2026
Date: 03/02/2026
To: All Licensed Financial Institutions
Subject: Operational Risk Management Regulation

تعميم رقم: 2026/1
التاريخ: 2026/02/03
إلى: كافة المنشآت المالية المرخصة
الموضوع: نظام إدارة المخاطر التشغيلية

Introduction

The Central Bank of the UAE seeks to promote the continuous development of an effective and efficient financial system. This regulation is issued pursuant to the powers vested under the Federal Decree-law No. (6) of 2025 Regarding the Central Bank, Regulation of Financial Institutions and Activities, and Insurance Business.

All Licensed Financial Institutions are required to implement a comprehensive framework to manage Operational Risk and Operational Resilience. This regulation establishes the minimum requirements in this regard.

Where this regulation includes requirements to provide specific information, to take specific measures or to address a specific list of items 'at a minimum', the Central Bank reserves the right to impose additional requirements to those articulated in this regulation.

The Central Bank may issue standards or guidelines that further elaborate on the requirements of this regulation.

Scope

This regulation applies to all Licensed Financial Institutions that are juridical persons.

Objective

The objective of this regulation is to set out the minimum requirements for Licensed Financial Institutions with regard to managing their Operational Risk and Operational Resilience.

مقدمة

يسعى المصرف المركزي إلى تعزيز التطوير المستمر الذي من شأنه أن يضمن عمل النظام المالي على نحو كفء وفعال. وقد تم إصدار هذا النظام عملاً بالصلاحيات الممنوحة للمصرف المركزي بموجب أحكام المرسوم بقانون اتحادي رقم (6) لسنة 2025 في شأن المصرف المركزي وتنظيم المنشآت والأنشطة المالية وأعمال التأمين.

يجب على كافة المنشآت المالية المرخصة تطبيق إطار شامل لإدارة المخاطر التشغيلية والمرونة التشغيلية، ويضع هذا النظام الحد الأدنى من المتطلبات في هذا الصدد.

وحيثما يتضمن هذا النظام متطلبات بتقديم معلومات أو اتخاذ إجراءات، أو التعامل مع قائمة بنود بعينها، مشار إليها "كحد أدنى"، يظل المصرف المركزي محتفظاً بالحق في أن يفرض متطلبات تكون إضافة للمتطلبات المنصوص عليها في هذا النظام.

كما قد يُصدر المصرف المركزي معايير أو إرشادات تضيف مزيداً من التوسع والتفصيل حول المتطلبات المنصوص عليها في هذا النظام.

النطاق

تنطبق أحكام هذا النظام على كافة المنشآت المالية المرخصة التي هي أشخاص اعتباريين.

الهدف

يهدف هذا النظام إلى وضع الحد الأدنى من المتطلبات للمنشآت المالية المرخصة، فيما يتعلق بإدارة مخاطرها التشغيلية ومرونتها التشغيلية.

Article (1): Definitions**المادة (1): تعريفات**

- 1-1 **بنك:** أي شخص اعتباري مرخص بموجب أحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له ليمارس، بصورة رئيسية، نشاط تلقي الودائع، بالإضافة إلى أي أنشطة مالية أخرى.
- 1.1. **Bank:** Any juridical person licensed in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof, to primarily carry on the activity of taking deposits in addition to any other financial activities.
- 2-1 **مجلس الإدارة:** مجلس إدارة أو مجلس مديرين المنشأة المالية المرخصة.
- 1.2. **Board:** the LFI's board of directors or board of managers.
- 3-1 **خطة استمرارية الأعمال:** خطة عمل مكتوبة وشاملة تحدد الإجراءات والنظم اللازمة لمواصلة أو استعادة عمليات المنشأة المالية المرخصة عند تعطلها أو اضطرابها.
- 1.3. **Business Continuity Plan:** a comprehensive written plan of action that sets out the procedures and systems necessary to continue or restore the operation of the LFI in the event of a disruption.
- 4-1 **المصرف المركزي:** مصرف الإمارات العربية المتحدة المركزي.
- 1.4. **Central Bank:** The Central Bank of the United Arab Emirates.
- 5-1 **قانون المصرف المركزي:** المرسوم بقانون اتحادي رقم (6) لسنة 2025 في شأن المصرف المركزي وتنظيم المنشآت والأنشطة المالية وأعمال التأمين.
- 1.5. **Central Bank Law:** Federal Decree-Law No. (6) of 2025 Regarding the Central Bank, Regulation of Financial Institutions and Activities, and Insurance Business.
- 6-1 **التغييرات في العمليات:** التغييرات في الأنشطة والعمليات والنظم، بما في ذلك إدخال عمليات جديدة، وإدخال تغييرات على عمليات قائمة، أو وقفها.
- 1.6. **Changes in Operations:** changes in activities, processes and systems, including the introduction of new operations, and changes to or the discontinuation of existing operations.
- 7-1 **وظائف الضبط:** وظائف المنشأة المالية المرخصة التي لها مهام مستقلة عن الإدارة لتقديم تقييم موضوعي و/أو رفع التقارير و/أو التدقيق؛ ويشمل ذلك وظيفة إدارة المخاطر، ووظيفة الامتثال، ووظيفة التدقيق الداخلي.
- 1.7. **Control Functions:** the LFI's functions that have a responsibility independent from management to provide objective assessment, reporting and/or assurance; this includes the risk management function, the compliance function and the internal audit function.
- 8-1 **الوظائف بالغة الأهمية:** الأنشطة أو الخدمات أو العمليات التي يرجح أن يؤدي انقطاعها إلى الإخلال بالاستقرار المالي، أو تعطيل أو اضطراب خدمات أساسية للاقتصاد بسبب حجم المنشأة المالية المرخصة، وحصتها في السوق وارتباطاتها الداخلية والخارجية، أو درجة تعقد أنشطتها عبر الحدود، مع أخذ اعتبار خاص لإمكانية استبدال تلك الأنشطة أو الخدمات أو العمليات.
- 1.8. **Critical Functions:** Activities, services or operations the discontinuance of which is likely to lead to the disruption of financial stability, or of services that are essential to the economy due to the size, market share, external and internal interconnectedness, complexity, cross-border activities of an LFI, with particular regard to the substitutability of those activities, services, or operations.

- 9-1 **الأصول المعلوماتية بالغة الأهمية:** الأصول البياناتية التي تكون سريتها أو سلامتها أو توفرها أمراً بالغ الأهمية للعمليات الحيوية للمنشأة المالية المرخصة، أو لامتنال المنشأة المالية المرخصة للمتطلبات القانونية والرقابية، بما في ذلك، على وجه الخصوص، المتطلبات الاحترازية المطبقة على المنشأة المالية المرخصة، وتلك التي تتعلق بحماية البيانات الشخصية.
- 1.9. **Critical Information Assets:** data assets whose confidentiality, integrity or availability is critical to the Critical Operations of the LFI or to the LFI's compliance with legal and regulatory requirements, including in particular the prudential requirements applicable to the LFI and those related to the protection of Personal Data.
- 10-1 **العمليات الحيوية:** تتضمن الوظائف بالغة الأهمية للمنشأة المالية المرخصة، وكافة الأنشطة والعمليات والخدمات، والأصول ذات الصلة الداعمة لها، والتي سيؤثر تعطيلها أو اضطرابها على استمرار عمل المنشأة المالية المرخصة، ودورها في النظام المالي، أو عملائها. ويعتمد ما إذا كانت عملية بعينها حيوية على طبيعة المنشأة المالية المرخصة، ودورها في النظام المالي ككل. للمصرف المركزي أن يحدد ما إذا كان يجب اعتبار عملية بعينها حيوية.
- 1.10. **Critical Operations:** includes an LFI's Critical Functions and all activities, processes, services and their relevant supporting assets, the disruption of which would impact the continued operation of the LFI, its role in the financial system, or its customers. Whether a particular operation is critical depends on the nature of the LFI and its role in the financial system. The Central Bank can indicate if a particular operation must be deemed critical.
- 11-1 **حادث:** حدث يكون له، أو من الممكن أن يكون له، تأثير ضار على العمليات الحيوية، أو على الأصول المعلوماتية بالغة الأهمية.
- 1.11. **Incident:** an event that has or could potentially have an adverse effect on Critical Operations, or on Critical Information Assets.
- 12-1 **تقنية المعلومات والاتصال:** تقنية المعلومات والاتصال.
- 1.12. **ICT:** Information and communication technology.
- 13-1 **مؤسسة مالية إسلامية:** البنوك وشركات التأمين التكافلي والمؤسسات المالية الأخرى المرخص لها، وفقاً لأحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له، لممارسة كافة أو جزءاً من أنشطتها وأعمالها وفقاً لأحكام ومبادئ الشريعة الإسلامية.
- 1.13. **Islamic Finance Institution ('IFI'):** Banks, Takaful Insurance Companies, and Other Licensed Financial Institutions in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof, to carry on the whole or a part of their activities and business in accordance with the rules and principles of the Islamic Shari'ah.
- 14-1 **شركة التأمين:** أي شخص اعتباري مُرخّص له، وفقاً لأحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له، بممارسة أعمال وأنشطة التأمين في الدولة.
- 1.14. **Insurance Company:** Any juridical person, licensed in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof to carry on insurance business and activities in the State.
- 15-1 **الأنشطة المالية المرخصة:** الأنشطة المالية الخاضعة لترخيص ورقابة المصرف المركزي والمُحددة في قانون المصرف المركزي، والأنظمة الصادرة تنفيذاً له.
- 1.15. **Licensed Financial Activity:** The financial activities subject to Central Bank licensing and supervision, which are specified in the Central Bank Law and the regulations issued in implementation thereof.

- 1.16. **Licensed Financial Institution ('LFI'):** Banks, (Re)Insurance Companies, and Other Financial Institutions licensed in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof, to carry on a Licensed Financial Activity or more, including those which carry on the whole or a part of their activities and business in accordance with the rules and principles of Islamic Shari'ah. These institutions shall be either incorporated inside the State or a branch or subsidiary inside the State of a financial institution incorporated outside the State or in Financial Free Zones.
- 16-1 **المنشأة المالية المرخصة:** البنوك وشركات التأمين وشركات إعادة التأمين والمؤسسات المالية الأخرى المرخصة، وفقاً لأحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له، لممارسة نشاط أو أكثر من الأنشطة المالية المرخصة، وتشمل تلك التي تمارس كافة أو جزء من أعمالها وأنشطتها وفقاً لمبادئ وأحكام الشريعة الإسلامية، وتكون تلك المنشآت إما مؤسسة داخل الدولة، أو فرعاً أو شركة تابعة داخل الدولة لمنشأة مالية مؤسسة خارج الدولة أو في المناطق الحرة المالية.
- 1.17. **Master System of Record:** the collection of all data, including Personal Data, required to conduct all Critical Operations of an LFI, including the provision of services to clients, managing all risks, and complying with all legal and regulatory requirements.
- 17-1 **نظام السجلات الرئيس:** تجميع كل البيانات، بما في ذلك البيانات الشخصية، المطلوبة لإجراء كافة العمليات الحيوية للمنشأة المالية المرخصة، بما في ذلك تقديم الخدمات للعملاء، وإدارة جميع المخاطر، والامتثال لكافة المتطلبات القانونية والرقابية.
- 1.18. **Operational Resilience:** the ability of an LFI to deliver Critical Operations through disruption, including by identifying and protecting itself from threats and potential failures, by responding and adapting to, and recovering and learning from disruptive events to minimise their impact on delivering Critical Operations through disruption.
- 18-1 **المرونة التشغيلية:** قدرة المنشأة المالية المرخصة على توفير العمليات الحيوية خلال حالات التعطل أو الاضطراب، بما في ذلك تحديد وحماية نفسها من التهديدات والأعطال المحتملة، من خلال الاستجابة والتكيف مع أحداث التعطل والاضطراب والتعافي من تأثيراتها والتعلم منها، لتقليل تأثيرها على توفير العمليات الحيوية في حالات التعطل أو الاضطراب.
- 1.19. **Operational Risk:** the risk of loss resulting from inadequate or failed internal processes, people and systems or from external events. This includes legal risk, but excludes strategic and reputational risk.
- 19-1 **المخاطر التشغيلية:** مخاطر الخسائر الناجمة عن عدم كفاية، أو إخفاق العمليات أو الأشخاص أو النظم الداخلية، أو عن أحداث خارجية. ويشمل هذا التعريف المخاطر القانونية، ولكنه لا يتضمن المخاطر الاستراتيجية أو مخاطر السمعة.
- 1.20. **Other Financial Institutions:** Any Person, except Banks and (Re)Insurance Companies, licensed in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof, to carry on a Licensed Financial Activity or more.
- 20-1 **المؤسسات المالية الأخرى:** أي شخص، فيما عدا البنوك وشركات التأمين وشركات إعادة التأمين، مرخص له وفقاً لأحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له، بممارسة نشاط مالي أو أكثر من الأنشطة المالية المرخصة.
- 1.21. **Outsourcing:** an agreement between an LFI and a Third-Party Service Provider whereby that Third-Party Service Provider performs a process, service or activity that would otherwise be undertaken by the LFI itself.
- 21-1 **التعهد:** اتفاقية بين منشأة مالية مرخصة ومزوّد خدمة خارجي، يقوم بموجبها مزوّد الخدمة الخارجي بأداء عملية أو خدمة أو

- نشاط كان من الممكن أن تقوم به المنشأة المالية المرخصة بنفسها.
- 22-1 **البيانات الشخصية:** حسبما ورد تعريفها في المرسوم بقانون اتحادي رقم (45) لسنة 2021 بشأن حماية البيانات الشخصية.
- 23-1 **شركة إعادة التأمين:** أي شخص اعتباري مُرخّص له، وفقاً لأحكام قانون المصرف المركزي والأنظمة الصادرة تنفيذاً له، بممارسة أعمال وأنشطة إعادة التأمين.
- 24-1 **شركة التأمين وشركة إعادة التأمين:** شركة التأمين و/أو شركة إعادة التأمين.
- 25-1 **تقبل المخاطر:** المستوى الإجمالي وأنواع المخاطر التي تكون المنشأة المالية المرخصة على استعداد لتحملها، والتي تقرر مسبقاً، ضمن قدرتها على تحمل المخاطر، بهدف تحقيق أهدافها الاستراتيجية وخطتها عملها.
- 26-1 **حدود المخاطر:** تدابير كمية تستند على افتراضات مستقبلية تُوزّع إجمالي بيان تقبل المخاطر للمنشأة المالية (على سبيل المثال، قياس الخسائر أو الأحداث السلبية) على خطوط أعمال أو كيانات قانونية، حسب الاقتضاء، وفئات المخاطر الخاصة، والتركيزات والمستويات الأخرى، حيثما يكون مناسباً.
- 27-1 **درجة تحمل المخاطر:** الفرق بينه وبين تقبل المخاطر المذكور أعلاه، أن المنشأة المالية المرخصة تكون راغبة في تحمل المخاطر.
- 28-1 **الإدارة العليا:** الإدارة التنفيذية للمنشأة المالية المرخصة، المسؤولة والمساءلة أمام مجلس الإدارة عن الإدارة اليومية السليمة والاحترازية للمنشأة المالية المرخصة، وتشمل بصورة عامة، على سبيل المثال لا الحصر، الرئيس التنفيذي، والمسؤول المالي الرئيسي، ومسؤول المخاطر الرئيسي، ورؤساء وظائف الامتثال والتدقيق الداخلي.
- 29-1 **مخاطر عدم الامتثال لأحكام الشريعة:** مخاطر الخسائر المالية أو مخاطر السمعة التي قد تتكبدها أو
- 1.22. **Personal Data:** as defined under Federal Decree-Law No. (45) of 2021 on Personal Data Protection.
- 1.23. **Reinsurance Company:** Any juridical person licensed in accordance with the provisions of the Central Bank Law and the regulations issued in implementation thereof to carry on reinsurance business and activities.
- 1.24. **(Re)Insurance Company:** an Insurance Company and/or Reinsurance Company.
- 1.25. **Risk Appetite:** The aggregate level and types of risk an LFI is willing to assume, decided in advance and within its risk capacity, to achieve its strategic objectives and business plan.
- 1.26. **Risk Limits:** Quantitative measures based on forward looking assumptions that allocate the financial institution's aggregate Risk Appetite statement (e.g. measure of loss or negative events) to business lines, legal entities as relevant, specific risk categories, concentrations, and as appropriate, other levels.
- 1.27. **Risk Tolerance:** The variation around the prescribed Risk Appetite that the LFI is willing to tolerate.
- 1.28. **Senior Management:** The executive management of the LFI responsible and accountable to the Board for the sound and prudent day-to-day management of the LFI, generally including, but not limited to, the chief executive officer, chief financial officer, chief risk officer, and heads of the compliance and internal audit functions.
- 1.29. **Shari'ah Non-Compliance Risk ('SNCR'):** risk of financial loss or reputational risk that

an LFI might incur or suffer for not complying with Islamic Shari'ah.

تعاني منها منشأة مالية مرخصة بسبب عدم امتثالها لأحكام الشريعة الإسلامية.

- 1.30. **Takaful Insurance Company:** An Insurance Company that carries on insurance business and activities in accordance with the rules and principles of Islamic Shari'ah, and the Central Bank Law and the regulations issued in implementation thereof.

30-1 **شركة التأمين التكافلي:** شركة تأمين تمارس أعمال وأنشطة التأمين وفقاً لأحكام ومبادئ الشريعة الإسلامية وقانون المصرف المركزي والأنظمة الصادرة تنفيذاً له.

- 1.31. **Third-Party Service Provider:** a natural or legal person that performs services, activities, functions, processes or tasks directly for an LFI, including in the form of Outsourcing but excluding employment as staff of the LFI.

31-1 **مزود الخدمة الخارجي:** الشخص الطبيعي أو الاعتباري الذي يؤدي خدمات أو أنشطة أو وظائف أو عمليات أو مهام للمنشأة المالية المرخصة بصورة مباشرة، بما في ذلك في هيئة تعهيد، ولكن باستثناء العمل كموظف لدى المنشأة المالية المرخصة.

Article (2): Operational Risk Management Framework

المادة (2): إطار إدارة المخاطر التشغيلية

- 2.1. An LFI must have in place an appropriate Operational Risk management framework that includes strategies, policies, procedures, systems, controls and processes to identify, assess, evaluate, monitor, report and control or mitigate Operational Risk on a timely basis.

1-2 يجب أن يكون لدى المنشأة المالية المرخصة إطار ملائم لإدارة المخاطر التشغيلية، يتضمن استراتيجيات وسياسات وإجراءات ونظم وضوابط وعمليات لتحديد المخاطر التشغيلية وتقييمها ومراقبتها ورفع تقارير بشأنها وضبطها أو تخفيفها في المواقف الملائمة.

- 2.2. The Operational Risk management framework must be fully integrated into the broader risk management and governance framework of the LFI.

2-2 يجب أن يتم دمج إطار إدارة المخاطر التشغيلية بالكامل في الإطار العام لإدارة المخاطر والحوكمة لدى المنشأة المالية المرخصة.

- 2.3. The LFI must ensure that its Operational Risk strategy, policies and processes are consistent with its risk profile, systemic importance, Risk Appetite, tolerance for disruption and capital strength, and take into account market and macroeconomic conditions. To this end, these must be reviewed and revised as appropriate, in particular whenever a material change in the Operational Risk profile occurs.

3-2 يجب على المنشأة المالية المرخصة التحقق من أن استراتيجيتها وسياسات وعمليات المخاطر التشغيلية لديها تتسق مع ملف مخاطرها وأهميتها النظامية وتقبلها للمخاطر ودرجة تحملها للأعطال والاضطرابات ومتانة رأس مالها، وتأخذ أوضاع السوق وأوضاع الاقتصاد الكلي في الاعتبار. ولتحقيق هذه الغاية، لا بد من مراجعة هذه العوامل وتعديلها حسبما يكون ملائماً، وعلى وجه الخصوص، عندما يحدث تغيير جوهري في ملف المخاطر التشغيلية.

- 2.4. The Operational Risk management framework must be comprehensive and address all material aspects of Operational Risk prevalent in the business of the LFI, considering in particular the risks inherent in

4-2 يجب أن يكون إطار إدارة المخاطر التشغيلية شاملاً ويتناول كافة الجوانب الجوهرية للمخاطر التشغيلية السائدة في أعمال المنشأة المالية المرخصة، وأخذاً في الاعتبار، بوجه خاص، المخاطر المتأصلة في

all material products, activities, processes and systems, including those Outsourced to or relying on Third Party Service Providers.	جميع المنتجات والأنشطة والعمليات والنظم الجوهرية، بما في ذلك تلك التي تم تعهدها أو الاعتماد فيها على مزود خدمة خارجي.
2.5. The Operational Risk management framework must be well documented and address the following at a minimum:	5-2 ويجب أن يكون إطار إدارة المخاطر التشغيلية موثقاً على نحو جيد، ويتناول ما يأتي، كحد أدنى:
2.5.1. The governance framework to manage Operational Risk in the form of a clear governance structure, including reporting lines, responsibilities and accountabilities, and a clear delegation of authority, including for the Operational Risk committee where applicable;	1-5-2 إطار الحوكمة لإدارة المخاطر التشغيلية في شكل هيكل حوكمة واضح، متضمناً التبعية الإدارية، والمسؤوليات، والمساءلة، وتفويض واضح للسلطة، بما في ذلك تفويض السلطات للجنة المخاطر التشغيلية، حيثما ينطبق ذلك؛
2.5.2. Operational Risk management policies and procedures, including in particular the Operational Risk Appetite and Tolerance;	2-5-2 سياسات وإجراءات إدارة المخاطر التشغيلية، بما في ذلك، على وجه الخصوص، تقبل المخاطر التشغيلية ودرجة تحملها؛
2.5.3. The tools that will be used to identify and assess risks and controls and how they will be used, including in particular by the three lines of defence, and how their effective design, implementation and operation will be ensured. These may include but are not limited to the tools listed in Annex 1 to this regulation;	3-5-2 الأدوات التي سيتم استخدامها لتحديد وتقييم المخاطر والضوابط وكيفية استخدامها، بما في ذلك، على وجه الخصوص، من قبل خطوط الدفاع الثلاث، وكيف يمكن ضمان تصميمها وتطبيقها وتشغيلها بشكل فعال. وقد يتضمن ذلك، على سبيل المثال لا الحصر، الأدوات الواردة في الملحق (1) لهذا النظام؛
2.5.4. Common terminology and standards that ensure consistency of risk identification and assessment throughout the LFI and, where applicable, group;	4-5-2 المصطلحات والمعايير المشتركة التي تضمن الاتساق في تحديد وتقييم المخاطر على مستوى المنشأة المالية المرخصة، وكذلك في المجموعة ككل حيثما ينطبق ذلك؛
2.5.5. The establishment and calibration of thresholds or Risk Limits for inherent and residual Operational Risk exposure, consistent with the LFI's Risk Appetite and Risk Tolerance, including what is considered a material operational loss;	5-5-2 وضع ومعايرة سقوف أو حدود للتعرض للمخاطر التشغيلية المتأصلة والمتبقية، بما يتوافق مع مستويات تقبل المخاطر ودرجة تحملها لدى المنشأة المالية المرخصة، بما في ذلك ما يعتبر خسائر تشغيلية كبيرة؛

- 2.5.6. The requirements for the ongoing monitoring and regular reporting against the thresholds and Risk Limits referred to in Article 2.5.5 above, including the content and frequency appropriate for the various recipients and the management information system, and any notification requirements; and
- 2.5.7. The approved risk mitigation strategies and instruments.
- 2.6. LFI must address and manage the risks related to internal and external fraud as part of its Operational Risk management framework, including Incidents or ongoing threats affecting their customers.
- 6-5-2 متطلبات المراقبة المستمرة ورفع التقارير بشكل منتظم عن سقف وحدود المخاطر المشار إليها في المادة 5-5-2 أعلاه، بما في ذلك المحتوى والتواتر الملائمين لمختلف المتلقين ولنظام المعلومات الإدارية، وأي متطلبات للإخطار؛
- 7-5-2 والاستراتيجيات والأدوات المعتمدة لتخفيف المخاطر.
- 6-2 يتوجب على المنشآت المالية المرخصة معالجة وإدارة المخاطر المتعلقة بالاحتيال الداخلي والخارجي، كجزء من إطار إدارة المخاطر التشغيلية، بما في ذلك الحوادث أو التهديدات المستمرة التي تؤثر على عملائهم.

Article (3): Operational Resilience

المادة (3): المرونة التشغيلية

- 3.1. An LFI must have an effective Operational Resilience strategy and associated policies, procedures, systems and controls that enable it to respond to, adapt to, recover from and learn from, disruptive events to minimise the impact of such events on delivering Critical Operations through disruption. This strategy must be well integrated into the LFI's Operational Risk management framework.
- 3.2. An LFI's Operational Resilience strategy must leverage the Operational Risk management framework to identify internal and external threats and potential failures in people, processes and systems on an ongoing basis, promptly assess the vulnerabilities of Critical Operations and manage the resulting risks.
- 3.3. The Operational Resilience strategy, policies and processes must set out the circumstances in which Senior Management must alert the Board of incidents of disruption or potential disruption, in particular disruption or potential disruption of Critical Operations.
- 1-3 يجب أن تكون لدى المنشأة المالية المرخصة استراتيجية فعالة للمرونة التشغيلية، وسياسات وإجراءات ونظم وضوابط مرتبطة بذلك، والتي تمكنها من الاستجابة للأحداث المعطلة والتكيف معها، والتعافي منها والتعلم منها لتقليل تأثير مثل هذه الأحداث على توفير العمليات الحيوية خلال فترات التعطل أو الاضطراب. ويجب دمج هذه الاستراتيجية بشكل جيد في إطار إدارة المخاطر التشغيلية للمنشأة المالية المرخصة.
- 2-3 يجب أن تستفيد استراتيجية المرونة التشغيلية للمنشأة المالية المرخصة من إطار إدارة المخاطر التشغيلية لتحديد التهديدات الداخلية والخارجية، والإخفاقات المحتملة للأفراد والعمليات والنظم، على أساس مستمر، وتقييم نقاط الضعف في العمليات الحيوية وإدارة المخاطر الناتجة، فوراً.
- 3-3 يجب أن تحدد استراتيجية المرونة التشغيلية وسياساتها وعملياتها الظروف التي يجب فيها على الإدارة العليا أن تنبّه مجلس الإدارة لتعطل أو اضطراب قائم أو محتمل، خاصة تعطل أو اضطراب قائم أو محتمل للعمليات الحيوية.

- 4-3 يجب على المنشآت المالية المرخصة تحديد عملياتها الحيوية وكافة الأصول اللازمة لتقديمها، بما في ذلك بصفة خاصة، الأشخاص والتقنيات والعمليات والبيانات والمرافق ومزودي الخدمات الخارجيين، بما في ذلك أي كيانات داخل المجموعة، والترابطات والتبعيات المتبادلة بينهم والتي تعتبر لازمة لأداء العمليات الحيوية خلال فترات التعطل أو الاضطراب. ويجب إضفاء الطابع الرسمي على ذلك برسم تخطيطي لكل واحدة من العمليات الحيوية، وتحديثه كجزء من عملية إدارة التغيير.
- 3-4 LFI must identify their Critical Operations and all assets required to deliver them, including in particular the people, technology, processes, data, facilities and Third-Party Service Providers, including any intragroup entities, and the interconnections and interdependencies among them that are necessary for the delivery of Critical Operations through disruption. This must be formalized in a mapping for each of the Critical Operations and updated as part of change management.
- 5-3 كما يجب، كحد أدنى، اعتبار ما يلي جزءاً من العمليات الحيوية:
- 3-5 At a minimum, the following must be considered as part of Critical Operations:
- 1-5-3 التشغيل المستمر لنظم الدفع وخدمات الدفع والخدمات الأخرى التي يكون فيها الوقت عنصراً مهماً لعملاء المنشأة المالية المرخصة؛
- 3-5.1. The continued operation of payment systems, payment services and other time-critical services for the LFI's customers;
- 2-5-3 قدرة المنشأة المالية المرخصة على الاحتفاظ بسجلات مالية دقيقة ومحدّثة لعملائها، ولنفسها؛
- 3-5.2. The ability of the LFI to maintain accurate and up to date financial records for its customers and itself;
- 3-5-3 قدرة المنشأة المالية المرخصة على قياس وإدارة ملائمتها وسيولتها في المواقف الملائمة، بما في ذلك تعرضاتها لكافة المخاطر الجوهرية؛
- 3-5.3. The ability of the LFI to measure and manage its solvency and liquidity in a timely manner, including its exposure to all material risks; and
- 4-5-3 وأي عملية يعتبرها المصرف المركزي حيوية.
- 3-5.4. Any operation deemed to be critical by the Central Bank.
- 6-3 يجب على المنشأة المالية المرخصة أن تطوّر وتحافظ وتراجع بانتظام خطط إدارة الطوارئ والتعطل والاضطرابات لكافة العمليات الحيوية، والتي تتألف من الآتي، كحد أدنى:
- 1-6-3 خطط الاستجابة للحوادث: مجموعة من العمليات للكشف عن الحوادث والاستجابة لها والتعافي منها، بما في ذلك، على سبيل المثال لا الحصر، حوادث الأمن السيبراني.
- 3-6.1. Incident response plans: a set of processes to detect, respond to and recover from Incidents, including in particular but not limited to cyber security Incidents.
- 2-6-3 خطة استمرارية الأعمال: خطة عمل مكتوبة شاملة، تحدد الإجراءات والنظم اللازمة لاستمرار واستعادة
- 3-6.2. Business continuity plan: a comprehensive written plan of action that sets out the procedures and systems necessary to continue or restore the operation of an

تشغيل المؤسسة في حالة حدوث تعطل أو اضطراب.
organisation in the event of a disruption.

- 3-6-3. خطة التعافي من الكوارث: خطة شاملة لإدارة حوادث الكوارث التي تؤثر على العمليات الحيوية، وتحديدًا تلك التي تتخذ شكل عدم توفر الأصول لفترة ممتدة أو بشكل دائم.
- 3.6.3. Disaster recovery plan: a comprehensive plan to manage disaster incidents affecting Critical Operations, in particular in the form of prolonged or permanent unavailability of assets.

المادة (4): دور مجلس الإدارة

Article (4): Role of the Board of Directors

- 1-4 تقع على عاتق مجلس الإدارة المسؤولية النهائية عن التحقق من توفر إطار ملائم لإدارة المخاطر التشغيلية لدى المنشأة المالية المرخصة، مدمج بالكامل في الإطار العام لإدارة المخاطر لدى المنشأة المالية المرخصة، والذي يتضمن إدارة المرونة التشغيلية. وتظل هذه المسؤولية النهائية على عاتق أعضاء مجلس الإدارة بغض النظر عن أي لجان تابعة لمجلس الإدارة يتم تشكيلها.
- 4.1. The members of the Board bear ultimate responsibility for ensuring that the LFI has an adequate Operational Risk management framework in place that is fully integrated into the LFI's broader risk management framework and that includes the management of Operational Resilience. This ultimate responsibility is retained by the members of the Board regardless of any Board committees set up.
- 2-4 يجب على مجلس الإدارة، وليس أي لجنة تابعة لمجلس الإدارة، أن يعتمد ويراجع، على الأقل سنويًا، كافة استراتيجيات وسياسات المخاطر التشغيلية والمرونة التشغيلية الرئيسية المعتمدة لدى المنشأة المالية المرخصة، وعلى وجه الخصوص:
- 4.2. The Board, and not a Board committee, must approve and review at least annually the LFI's key Operational Risk and Operational Resilience strategies and policies, in particular:
- 1-2-4 بيان تقبل المخاطر ودرجة تحمل المخاطر التشغيلية لدى المنشأة المالية المرخصة، والذي يوضح طبيعة وأنواع ومستويات المخاطر التشغيلية التي تكون المنشأة المالية المرخصة مستعدة لأخذها، ويضع حدود وسقوف المخاطر الملائمة التي يجب على المنشأة المالية المرخصة العمل ضمنها؛
- 4.2.1. The LFI's Risk Appetite and Tolerance statement for Operational Risk, articulating the nature, types and levels of Operational Risk the LFI is willing to assume, and that sets appropriate Risk Limits and thresholds within which the LFI must operate;
- 2-2-4 درجة تحمل المنشأة المالية المرخصة للتعطل والاضطرابات، مع الأخذ في الاعتبار قدراتها التشغيلية في مجموعة واسعة من السيناريوهات الشديدة ولكنها معقولة، التي قد تؤثر على عملياتها الحيوية. كما يجب أن تتناول سياسات مجلس الإدارة أيضًا الحالات التي تكون فيها قدرات المنشأة المالية المرخصة غير
- 4.2.2. The LFI's tolerance for disruption, considering its operational capabilities in a broad range of severe but plausible scenarios that would affect its Critical Operations. The Board's policies must also address instances where the LFI's capabilities are insufficient to meet its stated tolerance for disruption; and

كافية لمقابلة درجة تحمّل التعطّل
والاضطرابات التي تم تحديدها؛

- 4.2.3. The LFI's Business Continuity and Disaster Recovery Plans. 3-2-4 وخطط المنشأة الماليّة المُرخّصة لاستمرارية الأعمال والتعافي من الكوارث.

This review must consider current and expected circumstances and changes in the external environment and in the operations of the LFI.

يجب أن تأخذ هذه المراجعة في الاعتبار الظروف والتغيرات الحالية والمتوقعة في البيئة الخارجية، وفي عمليات المنشأة الماليّة المُرخّصة.

The Board may delegate the annual review of the Business Continuity and Disaster Recovery Plans to one of its committees, but the Board must itself approve the initial plans and subsequently review the plans at least every three (3) years.

ويجوز لمجلس الإدارة أن يفوض المراجعة السنوية لخطط استمرارية الأعمال والتعافي من الكوارث لواحدة من لجانها، ولكن يجب على مجلس الإدارة نفسه أن يعتمد الخطط الأولية، وأن يراجع الخطط لاحقاً كل ثلاث (3) سنوات على الأقل.

- 4.3. The Board must have in place a formal process to oversee Senior Management and ensure that the strategies and policies it has approved are implemented effectively at all decision levels, including the Operational Risk Appetite and tolerance for disruption and the associated limits and thresholds. 3-4 يجب أن تكون لدى مجلس الإدارة عملية رسمية للإشراف على الإدارة العليا والتحقق من تنفيذ الاستراتيجيات والسياسات التي اعتمدها على نحو فعال على كافة مستويات القرار، بما في ذلك مستويات تقبل المخاطر التشغيلية ودرجة تحمّل التعطّل والاضطرابات، والحدود والسقوف المرتبطة بذلك.

- 4.4. The Board must approve, oversee and ensure the effectiveness of the LFI's ICT and cybersecurity risk management framework. 4-4 يجب على مجلس الإدارة أن يعتمد إطار إدارة مخاطر تقنية المعلومات والاتصال والأمن السيبراني للمنشأة الماليّة المُرخّصة، والإشراف عليها والتحقق من فعاليتها.

- 4.5. The Board must ensure that the Operational Risk management framework is subject to an effective independent review by internal audit. 5-4 يجب على مجلس الإدارة التحقق من أن إطار إدارة المخاطر التشغيلية يخضع لمراجعة مستقلة فعّالة من قبل التدقيق الداخلي.

- 4.6. The Board must ensure that the LFI establishes and maintains a strong Operational Risk culture and control environment that supports and provides appropriate standards and incentives for professional and responsible behaviour. To this end, it must also ensure that its approach to Operational Risk and Resilience is clearly communicated to all relevant parties, including its staff, third parties and intragroup entities. 6-4 يجب على مجلس الإدارة أن يتحقق من أن المنشأة الماليّة المُرخّصة تنشئ وتحافظ على ثقافة مخاطر تشغيلية قوية وبيئة ضبط تدعم وتوفر المعايير والحوافز الملزمة للسلوك المهني والمسؤول. ولتحقيق ذلك، يجب عليه أيضاً التحقق من أن منهجيته في التعامل مع المخاطر والمرونة التشغيلية قد تم إبلاغها بوضوح تام لكافة الأطراف المعنية، بما في ذلك الموظفين، ومزودي الخدمات الخارجيين والكيانات الأخرى داخل المجموعة.

- 7-4 يكون مجلس الإدارة مسؤولاً عن تحديد متطلباته الخاصة برفع التقارير عن المخاطر، ويجب أن يكون على دراية بأي قصور في البيانات التي يتسلمها.
- 4.7. The Board is responsible for determining its own risk reporting requirements, and must be aware of any limitations in the data it receives.
- 8-4 يجب أن يظل مجلس الإدارة مطلعاً على إدارة المخاطر التشغيلية للمنشأة المالية المرخصة ومسؤولاً عنها، وأن يكون أعلى سلطة لاتخاذ القرارات بشأنها. وفي إطار هذه القيود، يجوز لمجلس الإدارة إنشاء لجنة أو أكثر من لجان مجلس الإدارة لتولي مهام الإشراف واستلام التقارير واتخاذ القرارات على مستوى أكثر تفصيلاً.
- 4.8. The Board must remain informed, responsible and the highest authority to take decisions regarding Operational Risk management of the LFI. Within these limitations, the Board may set up one or more Board committees to conduct oversight, receive reporting and take decisions at a more granular level.
- 9-4 يجب أن يكون لدى جميع المنشآت المالية المرخصة المصنفة من قبل المصرف المركزي على أنها ذات أهمية نظامية لجنة مخاطر تشغيلية تابعة لمجلس الإدارة، أو لجنة أخرى معينة من قبل مجلس الإدارة للتعامل مع المخاطر التشغيلية. وللمصرف المركزي، وفقاً لتقديره، أن يلزم منشآت مالية مرخصة أخرى بإنشاء لجان مخاطر تشغيلية تابعة لمجلس الإدارة، مع مراعاة، من بين أمور أخرى، حجم المنشأة المالية المرخصة ودرجة تعقيدها.
- 4.9. All LFIs designated as systemically important by the Central Bank must have a Board Operational Risk committee or other designated Board committee that addresses Operational Risk. The Central Bank may at its discretion require other LFIs to establish a Board Operational Risk committee, taking into account, among others, LFI size and complexity.

Article (5): Role of Senior Management

المادة (5): دور الإدارة العليا

- 1-5 يجب على الإدارة العليا أن تتحقق من أن إطار إدارة المخاطر التشغيلية، متضمناً استراتيجية المرونة التشغيلية، حسبما تم اعتماده من قبل مجلس الإدارة، قد تمت ترجمته إلى سياسات وعمليات وضوابط ونظم فعالة ومطبقة بشكل جيد على مستوى المنشأة المالية المرخصة.
- 5.1. Senior Management must ensure that the Operational Risk management framework, including the Operational Resilience strategy, as approved by the Board is translated into effective, well-implemented policies, processes, controls and systems throughout the LFI.
- 2-5 يجب على الإدارة العليا أن تراقب، بانتظام، ملف المخاطر التشغيلية والتعرضات التشغيلية الجوهرية للمنشأة المالية المرخصة، وأن تطبق عمليات وآليات إعداد تقارير فعالة ومتقنة، تمكن من الإدارة الاستباقية للمخاطر والمرونة التشغيلية من قبل مجلس الإدارة والإدارة العليا، بما في ذلك، على وجه الخصوص، خطوط الدفاع الثلاثة، ووحدات الأعمال.
- 5.2. Senior Management must regularly monitor the Operational Risk profile and material operational exposures of the LFI, and implement robust processes and reporting mechanisms that enable proactive management of Operational Risk and Resilience by the Board, Senior Management including in particular the three lines of defence, and the business units.
- 3-5 يجب على الإدارة العليا أن ترفع تقاريراً لمجلس الإدارة حول المخاطر والمرونة التشغيلية للمنشأة
- 5.3. Senior Management must report to the Board about the Operational Risk and Resilience of

- the LFI on a regular, timely and proactive basis.
- 5.4. Senior Management must report to the Board, and not to a Board committee, in a timely manner any breaches or expected breaches of the LFI's Operational Risk Appetite and Tolerance, and the associated thresholds and Risk Limits.
- 5.5. Senior Management must develop and maintain an internal control system that clearly assigns authority, responsibility and reporting relationships to encourage and maintain accountability throughout the LFI.
- 5.6. Senior Management must regularly, and at least annually for Banks and (Re)Insurance Companies, conduct an assessment of the LFI's internal control system, formalized in the form of a 'report on internal control'. The assessment must be presented to the Board and the report provided to the Board and the Central Bank. The report must contain a description of the key internal control measures for all material processes related to Critical Operations, the assessment, and an overview of the measures taken or planned to be taken to improve the Internal Control System.
- 5.7. Senior Management must regularly evaluate the design, implementation and effectiveness of the LFI's ICT and cybersecurity risk management.
- 5.8. Senior Management must ensure that sufficient resources are available at all levels of seniority and across all business lines in line with the LFI's Operational Risk Appetite and Tolerance, proportionate to each business unit's activities.
- المالية المُرخصة، على أساس منتظم، وفي المواقيت الملائمة، وعلى نحو استباقي.
- 4-5 يجب على الإدارة العليا أن تقدم، في الوقت المناسب، تقارير لمجلس الإدارة، وليس إلى لجنة تابعة لمجلس الإدارة، بشأن أي خروقات أو خروقات متوقعة لمستويات تقبل وتحمل المخاطر التشغيلية للمنشأة المالية المُرخصة، وحدود وسقوف المخاطر المرتبطة بذلك.
- 5-5 يجب على الإدارة العليا تطوير نظام للضوابط الداخلية والحفاظ عليه، يحدد بوضوح تام السلطات والمسؤوليات وعلاقات التبعية الإدارية، لتشجيع وتعزيز المساءلة على مستوى المنشأة المالية المُرخصة.
- 6-5 يجب على الإدارة العليا أن تقوم، بانتظام، و سنوياً على الأقل بالنسبة للبنوك وشركات التأمين وشركات إعادة التأمين، بإجراء تقييم لنظام الضوابط الداخلية لدى المنشأة المالية المُرخصة بشكل رسمي، في هيئة "تقرير حول الضوابط الداخلية". ويجب عرض التقييم على مجلس الإدارة، وتقديم التقرير لمجلس الإدارة والمصرف المركزي. ويجب أن يحتوي التقرير وصفاً لتدابير الضوابط الداخلية الرئيسية لكافة العمليات الجوهرية ذات الصلة بالعمليات الحيوية، والتقييم، بالإضافة إلى نظرة عامة على التدابير المتخذة، أو المخطط اتخاذها، بغرض تحسين نظام الضوابط الداخلية.
- 7-5 يجب على الإدارة العليا أن تقيم بانتظام تصميم وتنفيذ وفعالية إطار إدارة مخاطر تقنية المعلومات والاتصال ومخاطر الأمن السيبراني لدى المنشأة المالية المُرخصة.
- 8-5 يجب على الإدارة العليا أن تتحقق من توفر موارد كافية في جميع المستويات الوظيفية وفي كافة فروع الأعمال، وبما يتماشى مع تقبل وتحمل المخاطر التشغيلية للمنشأة المالية المُرخصة، وبما يتناسب مع أنشطة كل وحدة أعمال.

This includes ensuring that the LFI's activities are conducted by a sufficient number of staff with sufficient experience, technical capabilities and access to resources, and with

ويشمل ذلك التحقق من أن أنشطة المنشأة المالية المُرخصة يتم إجراؤها من قبل عدد كافٍ من الموظفين ممن لديهم خبرات كافية وقدرات فنية وإمكانية وصول للموارد، ولديهم قدر ملائم من

an appropriate amount of resources with sufficient authority dedicated to internal control, change management, and risk management activities.

الموارد بالإضافة إلى سلطات كافية مكرّسة للضبط الداخلي وإدارة التغيير وأنشطة إدارة المخاطر.

Senior Management must oversee that staff is subject to regular and appropriate training.

يجب على الإدارة العليا أن تشرف على التدريب المنتظم والمناسب للموظفين.

- 5.9. Senior Management must ensure that the corporate culture reflects and inspires a culture of strong Operational Risk management, and ensure that it sets standards and incentives for professional and responsible behaviour throughout the LFI.

9-5 وعلى الإدارة العليا أن تتحقق من أن الثقافة المؤسسية تعكس وتشجع ثقافة إدارة مخاطر تشغيلية قوية وفعالة، وتتحقق من أنها تضع معايير ومحفّزات للسلوك المهني والمسؤول على مستوى المنشأة الماليّة المُرخصة.

Article (6): Operational Risk Management Function

المادة (6): وظيفة إدارة المخاطر التشغيلية

- 6.1. Within its risk management function, an LFI must have an Operational Risk management function that is adequately resourced, enjoys a sufficient degree of independence, and for which the Chief Risk Officer is responsible and accountable.

1-6 يجب أن تكون لدى المنشأة الماليّة المُرخصة، ضمن وظيفة إدارة المخاطر، وحدة لإدارة المخاطر التشغيلية مزوّدة بموارد كافية، وتتمتع بدرجة كافية من الاستقلالية، ويكون مسؤول المخاطر الرئيسي مسؤولاً عنها.

- 6.2. The Operational Risk management function must be responsible for the following at a minimum:

2-6 يجب أن تكون وظيفة إدارة المخاطر التشغيلية مسؤولة عن الآتي، كحد أدنى:

- 6.2.1. Developing an independent view regarding the business units' identified material Operational Risks, the design and effectiveness of internal controls, and the Risk Tolerance;

1-2-6 تطوير وجهة نظر مستقلة بشأن المخاطر التشغيلية الجوهرية التي تم تحديدها في وحدات الأعمال، وبشأن تصميم وفعاليّة الضوابط الداخلية، ودرجة تحمّل المخاطر؛

- 6.2.2. Challenging the relevance and consistency of the business units' implementation of the Operational Risk management tools, measurement activities and reporting systems, and providing actionable recommendations;

2-2-6 التأكّد من ملائمة واتساق تطبيق وحدات الأعمال لأدوات إدارة المخاطر التشغيلية وأنشطة القياس ونظم رفع التقارير، وتقديم توصيات قابلة للتطبيق؛

- 6.2.3. Developing and maintaining the Operational Risk management and measurement policies, standards and guidelines;

3-2-6 تطوير، والحفاظ على، سياسات ومعايير وإرشادات لإدارة وقياس المخاطر التشغيلية؛

- 6.2.4. Reviewing and contributing to the monitoring and reporting of the Operational Risk profile; 4-2-6 مراجعة ملف المخاطر التشغيلية، والمساهمة في مراقبته ورفع التقارير بشأنه؛
- 6.2.5. Identifying external and internal threats and potential failures in processes, people and systems on an ongoing basis; 5-2-6 تحديد المهددات الخارجية والداخلية والإخفاقات المحتملة في العمليات والأفراد والنظم، على أساس مستمر؛
- 6.2.6. Assessing vulnerabilities of Critical Operations and managing the resulting risks; and 6-2-6 تقييم نقاط الضعف في العمليات الحيوية، وإدارة المخاطر الناتجة عن ذلك؛
- 6.2.7. Designing and providing Operational Risk training and raising awareness on Operational Risk among relevant stakeholders. 7-2-6 وتصميم وإتاحة برامج تدريب حول المخاطر التشغيلية، ورفع الوعي حول المخاطر التشغيلية في أوساط أصحاب المصلحة ذوي الصلة.
- 6.3. The Operational Risk management function must regularly report its findings and recommendations to the Board. 3-6 يجب على وظيفة إدارة المخاطر التشغيلية أن ترفع لمجلس الإدارة، بشكل منتظم، تقارير بشأن نتائج عملها وتوصياتها.

Article (7): Internal Control System

المادة (7): نظام الضبط الداخلي

- 7.1. The Operational Risk management framework must foster a strong control environment supported by an effective internal control system. 1-7 يجب أن يشجع إطار إدارة المخاطر التشغيلية على إرساء بيئة ضبط متينة، مدعومة بنظام ضبط داخلي فعال.
- 7.2. The internal control system must address the following components: 2-7 ويجب أن يتناول نظام الضبط الداخلي المكونات الآتية:
- 7.2.1. risk assessment; 1-2-7 تقييم المخاطر؛
- 7.2.2. control activities; 2-2-7 أنشطة الضبط؛
- 7.2.3. monitoring activities; and 3-2-7 أنشطة المراقبة؛
- 7.2.4. information and communication. 4-2-7 والمعلومات والاتصال.
- 7.3. The internal control system must cover all activities of the LFI, including those that rely in full or in part on Third-Party Service Providers. 3-7 يجب أن يغطي نظام الضبط الداخلي كافة أنشطة المنشأة المالية المرخصة، بما في ذلك الأنشطة التي تعتمد بالكامل أو جزئياً على مزودي خدمات خارجيين.
- 7.4. An effective internal control system consists of policies, processes and systems, and the control measures they include to mitigate, reduce the likelihood, or limit the impact of associated risks. Control measures may include, but are not limited to: 4-7 يتألف نظام الضبط الداخلي الفعال من سياسات وعمليات ونظم، بجانب تدابير الضبط المتضمنة فيها لتخفيف أو تقليل احتمالية أو الحد من تأثير المخاطر ذات الصلة. وقد تتضمن تدابير الضبط ما يأتي، على سبيل المثال لا الحصر:

7.4.1.	Clearly established authorities and processes for approval;	1-4-7	صلاحيات وعمليات واضحة للموافقات؛
7.4.2.	Segregation of duties;	2-4-7	فصل بين الواجبات؛
7.4.3.	Dual control, whereby the process or system is designed such that two or more independent units (usually persons) operate in concert to protect sensitive functions or information;	3-4-7	ضبط مزدوج، يتم بموجبه تصميم العملية أو النظام بحيث تعمل وحدتان مستقلتان أو أكثر (عادةً أشخاص) بانسجام لحماية الوظائف أو المعلومات الحساسة؛
7.4.4.	Systematic monitoring of adherence to risk thresholds and Risk Limits, including those prescribed in the Risk Appetite and Tolerance;	4-4-7	مراقبة نظامية للالتزام بحدود وسقوف المخاطر، بما في ذلك حدود وسقوف المخاطر المنصوص عليها في بيان تقبل وتحمل المخاطر؛
7.4.5.	Safeguards for access to and use of the LFI's assets or those entrusted to the LFI, including data, and measures for the early detection and reporting of unauthorized access or misuse of assets;	5-4-7	إجراءات وقائية للتحكم في الوصول إلى أصول المنشأة المالية المرخصة أو تلك المعهد بها إليها واستخدامها، بما في ذلك البيانات، وتدابير الكشف المبكر والإبلاغ عن الوصول غير المصرح به أو إساءة استخدام الأصول؛
7.4.6.	Ongoing processes to identify business lines or products where returns or other indicators appear to be out of line with reasonable expectations;	6-4-7	عمليات مستمرة لتحديد فروع الأعمال أو المنتجات التي يبدو أن عائدها أو مؤشرات الأخرى غير متوافقة مع التوقعات المعقولة؛
7.4.7.	Regular verification and reconciliation of transactions, accounts, and risk indicators; and	7-4-7	تحقق ومطابقة منتظمة للمعاملات، والحسابات، ومؤشرات المخاطر؛
7.4.8.	A vacation policy that requires officers and employees to take a minimum leave of absence determined by the LFI.	8-4-7	وسياسة إجازات تلزم المسؤولين والموظفين بأخذ حد أدنى من الإجازة يتم تحديده من قبل المنشأة المالية المرخصة.
7.5.	Risk transfer and mitigation tools such as insurance may be used as complementary to, but not as a replacement for internal Operational Risk management and controls.	5-7	يجوز استخدام أدوات نقل وتخفيف المخاطر، مثل التأمين، كوسائل تكميلية للإدارة والضوابط الداخلية للمخاطر التشغيلية، ولكن ليس كبديل لها.
7.6.	The internal control system must address Operational Resilience and must itself be resilient by accounting for potential contingencies in processes, procedures and systems, including the availability of key assets.	6-7	يجب أن يتناول نظام الضبط الداخلي المرونة التشغيلية، ويجب أن يكون هو نفسه مرئياً من خلال مراعاة الطوارئ المحتملة في العمليات والإجراءات والنظم، بما في ذلك توفر الأصول الرئيسية.
7.7.	As part of the periodic review of processes and control measures, LFIs must identify processes and controls that involve manual interventions and evaluate whether these can	7-7	كجزء من المراجعة الدورية للعمليات والضبط، يجب على المنشآت المالية المرخصة تحديد العمليات والضوابط التي تتضمن تدخلات يدوية،

be automated, for example through integration into and enforcement by ICT systems.

وتقييم ما إذا كان من الممكن أتمتتها، على سبيل المثال من خلال دمجها في، وإنفاذها من خلال، نظم تقنية المعلومات والاتصال.

Conversely, for processes and controls that are automated, the effectiveness and accuracy of the automation must form part of periodic assessments and a LFI must identify, measure, monitor and manage the related technology risks.

وبالمقابل، وبالنسبة للعمليات والضوابط المؤتمتة، يجب أن تشكل فعالية ودقة الأتمتة جزءاً من التقييمات الدورية، ويجب على المنشأة المالية المُرخصة أن تتولى مهمة تحديد وقياس ومراقبة وإدارة مخاطر التقنية ذات الصلة.

- 7.8. An LFI must maintain a register of its processes (a 'process universe') that lists all processes with the process owner and risk owner.
- 8-7 يجب على المنشأة المالية المُرخصة الاحتفاظ بسجل لعملياتها ("الحصر الشامل للعمليات") يتضمن قائمة بكافة العمليات ويبيّن مالك العملية ومالك المخاطر.
- 7.9. The internal control system must incorporate the "three lines of defence" approach, distinguishing responsibilities and accountability between:
- 9-7 يجب أن يتضمن نظام الضبط الداخلي منهجية "خطوط الدفاع الثلاثة"، مع تمييز المسؤوليات والمسائلة بين:
- 7.9.1. Business line management responsible for identification and control of risks on an ongoing basis;
- 1-9-7 إدارة فرع الأعمال المسؤولة عن تحديد وضبط المخاطر على أساس مستمر؛
- 7.9.2. Control functions of risk management and compliance; and
- 2-9-7 وظائف التحكم في إدارة المخاطر والامتثال؛
- 7.9.3. Internal audit to provide independent assurance.
- 3-9-7 والتدقيق الداخلي، لتوفير التأكيدات المستقلة.
- 7.10. An LFI's internal control system must include effective processes and systems to regularly monitor Operational Risk profiles and material Operational Risk exposures. This must include reporting mechanisms to report to the Board, Senior Management, business units and the Control Functions.
- 10-7 يجب أن يتضمن نظام الضبط الداخلي للمنشأة المالية المُرخصة عمليات فعالة ونظم لمراقبة ملفات المخاطر التشغيلية والتعرضات الجوهرية للمخاطر التشغيلية بشكل منتظم. ويجب أن يتضمن ذلك آلية لرفع التقارير لمجلس الإدارة والإدارة العليا ووحدات الأعمال ووظائف الضبط.
- The reporting mechanisms must ensure that reports:
- ويجب أن تضمن آليات رفع التقارير ما يأتي:
- 7.10.1. are comprehensive, accurate, consistent and actionable;
- 1-10-7 أن التقارير شاملة ودقيقة ومتسقة وقابلة للتنفيذ؛
- 7.10.2. are timely in both normal and stressed conditions, and at a frequency that reflects the nature of and pace at which risks may develop; and
- 2-10-7 وأنها تُرفع في المواقف المحددة، في الظروف العادية وفي ظروف الضغط، وبتواتر يعكس طبيعة المخاطر والسرعة التي قد تتطور بها؛

- 7.10.3. provide aggregate information with appropriate supporting detail to enable the recipients to understand and assess the LFI's Operational Risk exposures. 3-10-7 وأنها توفر معلومات إجمالية، مع تفاصيل داعمة وملائمة لتمكين متلقيها من فهم وتقييم تعرضات المنشأة المالية المُرخصة للمخاطر التشغيلية.
- 7.11. Operational Risk reports must describe the Operational Risk profile of the LFI through internal and external indicators and insights relevant to decision making. To this end, Operational Risk reports must contain: 11-7 يجب أن تقدم تقارير المخاطر التشغيلية وصفاً لملف المخاطر التشغيلية للمنشأة المالية المُرخصة من خلال مؤشرات داخلية وخارجية، ومرئيات ذات صلة باتخاذ القرارات. ولتحقيق هذه الغاية، يجب أن تحتوي تقارير المخاطر التشغيلية ما يأتي:
- 7.11.1. a description of the Operational Risk profile that refers to internal and external financial, operational and compliance indicators, events and conditions relevant to decision making; 1-11-7 وصفاً لملف المخاطر التشغيلية الذي يشير إلى المؤشرات المالية والتشغيلية والامتثالية، الداخلية والخارجية، والأحداث والظروف ذات الصلة بعملية اتخاذ القرار؛
- 7.11.2. an overview of the LFI's Operational Risk Limits, thresholds and other indicators relevant to its Risk Appetite and Tolerance; 2-11-7 نظرة عامة على سقوف وحدود المخاطر التشغيلية للمنشأة المالية المُرخصة، والمؤشرات الأخرى ذات الصلة بتقبلها وتحملها للمخاطر؛
- 7.11.3. clear statements on residual Operational Risks, control deficiencies, any non-compliance with Operational Risk or Resilience Tolerances, and Operational Risk events; 3-11-7 بيانات واضحة عن المخاطر التشغيلية المتبقية، وأي أوجه قصور في ضبطها، أو عدم امتثال لحدود تحمل المخاطر أو المرونة التشغيلية، وأحداث المخاطر التشغيلية؛
- 7.11.4. an overview and assessment of key and emerging risks; 4-11-7 نظرة عامة وتقييم للمخاطر الرئيسية والناشئة؛
- 7.11.5. details of recent significant internal Operational Risk and Resilience events and losses, including a root cause analysis; 5-11-7 تفاصيل عن آخر الأحداث والخسائر الداخلية الكبيرة المتعلقة بالمخاطر والمرونة التشغيلية، بما في ذلك تحليلاً للسبب الجذري؛
- 7.11.6. relevant external events and indicators, regulatory changes and any potential impact on the LFI; and 6-11-7 الأحداث والمؤشرات الخارجية ذات الصلة، والتغييرات الرقابية وأي تأثير محتمل لها على المنشأة المالية المُرخصة؛
- 7.11.7. relevant recommendations, including by the second line of defence, internal audit and external audit functions, in particular those 7-11-7 والتوصيات ذات الصلة، بما في ذلك من خلال خط الدفاع الثاني، ووظائف التدقيق الداخلي والخارجي، وبالأخص تلك

relating to the accuracy, comprehensiveness or consistency of the report. المتعلقة بدقة أو شمولية أو اتساق التقرير.

- 7.12. Operational Risk reports must be regularly reviewed to ensure they are comprehensive, accurate, consistent and actionable, and capture and reflect any changes in the activities or the environment of the LFI. The results of such reviews should be reported to the Board and Senior Management. 12-7 يجب مراجعة تقارير المخاطر التشغيلية بصورة منتظمة للتحقق من أنها شاملة ودقيقة ومتسقة وقابلة للتنفيذ، وأنها تلتقط وتعكس أي تغيرات في أنشطة أو بيئة المنشأة المالية المرخصة. ويجب رفع تقارير حول نتائج هذه المراجعة إلى مجلس الإدارة والإدارة العليا.
- 7.13. An LFI must periodically conduct stress-tests related to Operational Risk, including through exercises that challenge the LFI's control environment, for example through penetration testing. This includes but is not limited to ICT systems, physical controls, controls relying on people, and any other risk vectors. 13-7 يجب على المنشأة المالية المرخصة القيام بصورة دورية بإجراء اختبارات ضغط تتعلق بالمخاطر التشغيلية، بما في ذلك من خلال ممارسات اختبار بيئة الضبط لدى المنشأة المالية المرخصة، على سبيل المثال من خلال اختبار الاختراق. ويتضمن ذلك، على سبيل المثال لا الحصر، نظم تقنية المعلومات والاتصال، والضوابط العينية، والضوابط التي تعتمد على الأشخاص، وأي عوامل أخرى تشكل المخاطر.
- 7.14. At least for Critical Functions, the periodic testing referred to in Article 7.13 above must include penetration testing by an independent third party. The results must be presented to the Board. 14-7 وبالنسبة للوظائف بالغة الأهمية على الأقل، يجب أن يتضمن الاختبار الدوري المشار إليه في المادة 7-13 أعلاه اختبار اختراق من قبل طرف خارجي مستقل. ويجب عرض النتيجة على مجلس الإدارة.

Article (8): ICT and Cybersecurity Management

المادة (8): إدارة تقنية المعلومات والاتصال والأمن السيبراني

- 8.1. An LFI must implement a robust ICT and cybersecurity risk framework within its Operational Risk management framework and Operational Resilience approach, and have appropriate policies, processes and systems that address: 1-8 يجب على المنشأة المالية المرخصة أن تطبق إطارًا فعالًا ومتقنًا لمخاطر تقنية المعلومات والاتصال والأمن السيبراني ضمن إطار إدارة المخاطر التشغيلية ومنهجية إدارة المرونة التشغيلية، وتكون لديها سياسات وعمليات ونظم ملائمة، لتتولى معالجة:
- 8.1.1. ICT risk identification and assessment; 1-1-8 تحديد وتقييم مخاطر تقنية المعلومات والاتصال؛
- 8.1.2. ICT risk mitigation measures consistent with the assessed risk level, such as policies, processes and systems addressing cybersecurity, response and recovery, change management, and incident management; 2-1-8 وضع تدابير تخفيف لمخاطر تقنية المعلومات والاتصال، تتسق مع مستويات المخاطر التي تم تقييمها، مثل السياسات والعمليات والنظم الخاصة بالأمن السيبراني، والاستجابة والتعافي، وإدارة التغيير، وإدارة الحوادث؛

- 8.1.3. Regular monitoring and testing of mitigating measures; and 3-1-8 المراقبة والاختبارات المنتظمة لتدابير التخفيف؛
- 8.1.4. Ongoing, proactive management of ICT and cybersecurity risks. 4-1-8 والإدارة المستمرة والاستباقية لمخاطر تقنية المعلومات والاتصال والأمن السيبراني.
- 8.2. An LFI's Risk Appetite and Tolerance must address ICT and cybersecurity risk and Resilience, including clear expectations in terms of performance, Resilience and tolerance for disruption. 2-8 يجب أن يتناول ملف تقبل المخاطر وتحمل المخاطر لدى المنشأة المالية المُرخصة مخاطر ومرونة تقنية المعلومات والاتصال والأمن السيبراني، بما في ذلك توقعات واضحة من حيث الأداء والمرونة وتحمل حالات التعطل والاضطرابات.
- 8.3. An LFI must maintain appropriate ICT and cybersecurity infrastructure to meet its current and projected business requirements under normal circumstances and in periods of stress. This infrastructure must ensure data and system integrity, confidentiality and availability and, support integrated and comprehensive risk management. 3-8 يجب على المنشأة المالية المُرخصة الاحتفاظ ببنية أساسية ملائمة لتقنية المعلومات والاتصال والأمن السيبراني لتلبية متطلبات أعمالها الحالية والمتوقعة في ظل الظروف العادية وفي فترات الضغط. ويجب أن تضمن هذه البنية الحيوية سلامة وسرية وتوفير البيانات والنظم، وأن تدعم الإدارة المتكاملة والشاملة للمخاطر.
- 8.4. The Board and Senior Management must be regularly informed about the LFI's ICT and cybersecurity risk exposures, including about incidents and weaknesses identified in assessments and testing of its risk mitigating measures or ICT Resilience. 4-8 يجب إبلاغ مجلس الإدارة والإدارة العليا بانتظام بمخاطر تقنية المعلومات والاتصال والأمن السيبراني التي تتعرض لها المنشأة المالية المُرخصة، بما في ذلك الحوادث ونقاط الضعف التي تم تحديدها في تقييمات واختبارات تدابير التخفيف من المخاطر أو مرونة تقنية المعلومات والاتصال.
- 8.5. An LFI must ensure resilient ICT and cybersecurity that is subject to protection, detection, response and recovery programmes. 5-8 يجب على المنشأة المالية المُرخصة ضمان مرونة تقنية المعلومات والاتصال والأمن السيبراني الخاضعة لبرامج الحماية والكشف والاستجابة والتعافي.
- These programmes must be regularly tested, incorporate situational awareness, and convey timely information for risk management and decision-making processes that support and facilitate the delivery of Critical Operations. يجب اختبار هذه البرامج بانتظام، والتي يجب أن تتضمن الوعي الظرفي، وأن تنقل المعلومات في الوقت المناسب لإدارة المخاطر وعمليات صنع القرار التي تدعم وتسهل تنفيذ العمليات الحيوية.
- 8.6. At a minimum, the ICT and cybersecurity policy must address the following in support and alignment of the LFI's business objectives: 6-8 ولدعم ومواءمة الأهداف التجارية للمنشأة المالية المُرخصة، يجب أن تتناول سياسة تقنية المعلومات والاتصال والأمن السيبراني ما يأتي، كحد أدنى:
- 8.6.1. Governance and oversight controls; 1-6-8 ضوابط الحوكمة والإشراف؛

8.6.2.	Risk ownership, accountability and compliance;	مسؤولية المخاطر، والمساءلة، والامتثال؛	2-6-8
8.6.3.	ICT security measures such as access controls, identity management, Critical Information Asset protection, network security, vendor management security, physical and environmental security, vulnerability testing, and information classification;	تدابير أمن تقنية المعلومات والاتصال، مثل ضوابط الوصول، وإدارة الهوية، وحماية الأصول المعلوماتية بالغة الأهمية، وأمن الشبكة، وإدارة أمن الموردين، والأمن المادي والبيئي، واختبار نقاط الضعف، وتصنيف المعلومات؛	3-6-8
8.6.4.	Regular evaluation and monitoring of ICT controls and policy thresholds and limits, including risk Appetite and Tolerance thresholds;	التقييم والمراقبة المنتظمة لضوابط تقنية المعلومات والاتصال، وسياسة الحدود القصوى والسقوف، بما في ذلك سقوف تقبل وتحمل المخاطر؛	4-6-8
8.6.5.	Data management;	إدارة البيانات؛	5-6-8
8.6.6.	ICT operations and service management, such as change management and patch management;	إدارة عمليات وخدمات تقنية المعلومات والاتصال، مثل إدارة التغيير وإدارة حزم التصحيح؛	6-6-8
8.6.7.	Incident Response and Recovery Plans, Business Continuity Plans, and Disaster Recovery Plans;	خطط الاستجابة للحوادث والتعافي، وخطط استمرارية الأعمال، وخطط التعافي من الكوارث؛	7-6-8
8.6.8.	ICT project management; and	إدارة مشاريع تقنية المعلومات والاتصال؛	8-6-8
8.6.9.	Systems development and acquisition.	وتطوير النظم واقتنائها.	9-6-8
8.7.	An LFI's ICT and cybersecurity risk management and the related processes must:	وفيما يخص إدارة مخاطر تقنية المعلومات والاتصال والأمن السيبراني، والعمليات ذات الصلة، لدى المنشأة المالية المُرخصة، فيجب:	7-8
8.7.1.	Be reviewed regularly to remain compliant with relevant industry standard and best practices, and to address new and evolving technologies and threats;	أن تتم مراجعتها بشكل منتظم لتظل متوافقة مع معايير الصناعة ذات الصلة وأفضل الممارسات، ولتتعامل مع التقنيات والتهديدات الجديدة والناشئة؛	1-7-8
8.7.2.	Be regularly tested to identify gaps against its Risk Tolerance and to review and improve ICT and cybersecurity risk identification,	وأن يتم اختبارها بشكل منتظم للتعرف على الفجوات في تحمل المخاطر، ولمراجعة وتحسين تحديد مخاطر تقنية	2-7-8

- protection, detection and event management; and المعلومات والاتصال والأمن السيبراني والحماية منها وكشفها، وإدارة الأحداث؛
- 8.7.3. Make use of actionable intelligence to continuously enhance the LFI's cybersecurity posture, situational awareness of vulnerabilities to ICT systems, networks and applications and to support effective decision making in risk and change management. وأن تتم الاستفادة من المعلومات القابلة للتنفيذ، لتعزيز وضع الأمن السيبراني لدى المنشأة المالية المُرخّصة بشكل مستمر، والوعي الظرفي بالثغرات في نظم وشبكات وتطبيقات تقنية المعلومات والاتصال، ودعم اتخاذ القرارات الفعالة في إدارة المخاطر والتغيير. 3-7-8
- 8.8. LFIs must proactively manage their ICT and cybersecurity systems, including those operated or made available by Third-Party Service Providers, and have a strategy and timeline for the timely renewal or discontinuation of obsolete and unsupported hardware and software systems. يجب على المنشآت المالية المُرخّصة إدارة نظم تقنية المعلومات والاتصال والأمن السيبراني الخاصة بها بشكل استباقي، بما في ذلك تلك التي يتم تشغيلها أو توفيرها من قبل مزودي خدمات خارجيين، وأن يكون لديها استراتيجية وجدول زمني لتجديد نظم الأجهزة والبرامج القديمة وغير المدعومة أو إيقاف تشغيلها، في الوقت المناسب. 8-8
- 8.9. An LFI's Master System of Record must be continuously maintained and stored within the UAE, including in the case of Outsourcing. LFIs that are branches of foreign financial institutions may, subject to Central Bank approval, comply with this requirement by maintaining an up-to-date copy of the Master System of Record in the UAE. يجب الاحتفاظ بنظام السجلات الرئيس للمنشأة المالية المُرخّصة وتخزينه بشكل مستمر داخل دولة الإمارات العربية المتحدة، بما في ذلك في حالات التعهيد. ويجوز للمنشآت المالية المُرخّصة التي هي فروع لمؤسسات مالية أجنبية الامتثال لهذا المطلب من خلال الاحتفاظ بنسخة محدثة من نظام السجلات الرئيس في دولة الإمارات العربية المتحدة، بشرط موافقة المصرف المركزي. 9-8
- 8.10. An LFI must comply with the regulations regarding ICT, cyber and information security issued by the relevant authorities in the UAE. يجب على المنشأة المالية المُرخّصة الامتثال للأنظمة الصادرة عن السلطات المختصة بدولة الإمارات العربية المتحدة، بشأن تقنية المعلومات والاتصال والأمن السيبراني وأمن المعلومات. 10-8

Article (9): Incident Management

المادة (9): إدارة الحوادث

- 9.1. An LFI must develop and implement Incident Response and Recovery Plans to manage Incidents that could disrupt the delivery or Resilience of Critical Operations in line with its Risk Appetite and tolerance for disruption. يجب على المنشأة المالية المُرخّصة أن تطور وتطبق خطط استجابة للحوادث والتعافي، لإدارة الحوادث التي يمكن أن تعطل أو تُربك أداء أو مرونة العمليات الحيوية، بما يتماشى مع مستويات تقبلها للمخاطر ومدى تحملها للتعطّل والاضطرابات. 1-9
- For the avoidance of doubt, this includes but is not limited to ICT and cybersecurity Incidents. ولتفادي أي شكوك، يشمل ذلك، على سبيل المثال لا الحصر، حوادث تقنية المعلومات والاتصال والأمن السيبراني.

- 9.2. An LFI must regularly review, test and update its Incident Response and Recovery Plans, based on lessons learned from previous Incidents. In particular, an LFI must identify and address the root cause of all material Incidents and implement measures to prevent them or reduce the likelihood of further similar Incidents occurring.
- 2-9 يجب على المنشأة المالية المُرخصة أن تقوم بمراجعة واختبار وتحديث خطط الاستجابة للحوادث والتعافي، بناءً على الدروس المستفادة من الحوادث السابقة. وعلى وجه الخصوص، يجب على المنشأة المالية المُرخصة تحديد ومعالجة السبب الجذري لجميع الحوادث الجوهرية، وتطبيق تدابير لمنعها أو تقليل احتمالية وقوع حوادث أخرى مماثلة لها.
- The effectiveness of this process must be measured and periodically reviewed.
- ويجب قياس فعالية هذه العملية ومراجعتها بشكل دوري.
- 9.3. An LFI must maintain an inventory of all relevant resources required for supporting its response and recovery capabilities, including internal and third-party resources.
- 3-9 يجب على المنشأة المالية المُرخصة الاحتفاظ بمخزون لجميع الموارد ذات الصلة المطلوبة لدعم قدرات الاستجابة والتعافي، بما في ذلك الموارد الداخلية وموارد الجهات الخارجية.
- 9.4. Incident management must cover the full life cycle of an Incident, including at a minimum:
- 4-9 يجب أن تغطي إدارة الحوادث كامل دورة حياة الحادث، بما في ذلك، كحد أدنى:
- 9.4.1. Classification of an Incident's severity based on predefined criteria, such as the impact and expected time to return to normal operation, that permits appropriate prioritisation and assignment of resources to respond to the Incident;
- 1-4-9 تصنيف شدة الحادث بناءً على معايير محددة مسبقاً، مثل التأثير والوقت المتوقع للعودة إلى التشغيل العادي، بما يتيح إمكانية تحديد الأولويات المناسبة، وتخصيص الموارد للاستجابة للحادث؛
- 9.4.2. Incident response and recovery procedures, and how they relate to other contingency measures such as the Business Continuity Plan;
- 2-4-9 إجراءات الاستجابة للحادث والتعافي، وكيفية ارتباطها بتدابير طوارئ أخرى، مثل خطة استمرارية الأعمال؛
- 9.4.3. Roles and responsibilities of staff and external parties with regard to the recording, analysis, escalation, decision-making, resolution and monitoring of Incidents;
- 3-4-9 أدوار ومسؤوليات الموظفين ومزودي الخدمات الخارجيين فيما يتعلق بتسجيل الحوادث وتحليلها وتصعيدها واتخاذ القرارات بشأنها وحلها ومراقبتها؛
- 9.4.4. Communication plans to report incidents to internal and external stakeholders, including to the Central Bank and other authorities where required, that include reporting relevant performance metrics for ongoing Incidents and an analysis with lessons learned after an Incident has been resolved; and
- 4-4-9 خطط اتصال للإبلاغ عن الحوادث لأصحاب المصلحة الداخليين والخارجيين، بما في ذلك المصرف المركزي والسلطات الأخرى عندما يكون ذلك مطلوباً، والتي تتضمن الإبلاغ عن مقاييس الأداء ذات الصلة للحوادث الجارية وتحليل الدروس المستفادة بعد أن يتم حل ومعالجة الحادث؛

- 9.4.5. Documentation of all Incidents in a register, including the nature of the Incident, the actions taken and the outcomes. 5-4-9 وتوثيق كافة الحوادث في سجل، بما في ذلك طبيعة الحادث والإجراءات المتخذة والنتائج.
- 9.5. An LFI's incident management must cover all Critical Operations and address all relevant resources required to maintain their Resilience and continuity, as per the mapping required under Article 3.4 of this Regulation. 5-9 يجب أن تغطي إدارة الحوادث لدى المنشأة المالية المرخصة كافة العمليات الحيوية، وتتناول كافة الموارد ذات الصلة المطلوبة للحفاظ على مرونة هذه العمليات واستمراريتها، وفقاً للرسم التخطيطي المطلوب بموجب أحكام المادة 3-4 من هذا النظام.

Article (10): Risk Data and Systems

المادة (10): بيانات ونظم المخاطر

- 10.1. An LFI's risk information systems must deliver the capabilities and performance necessary, reflecting the LFI's risk profile, complexity and systemic importance, including during stressed circumstances or a crisis. 1-10 يجب أن توفر نظم مخاطر المعلومات لدى المنشأة المالية المرخصة، القدرات والأداء اللازمين، بما يعكس ملف مخاطر المنشأة المالية المرخصة، ودرجة تعقد عملياتها، وأهميتها النظامية، بما في ذلك خلال ظروف الضغط أو الأزمات.
- 10.2. An LFI must have in place adequate governance arrangements and internal controls to effectively manage and protect data. 2-10 يجب أن تكون لدى المنشأة المالية المرخصة ترتيبات حوكمة وضوابط داخلية كافية لإدارة وحماية البيانات على نحو فعال.
- 10.3. An LFI's ICT systems must enable the LFI to effectively: 3-10 يجب على نظم تقنية المعلومات والاتصال لدى المنشأة المالية المرخصة أن تمكن من القيام بما يأتي بشكل فعال:
- 10.3.1. monitor Operational Risk and Resilience on a timely and ongoing basis; 1-3-10 مراقبة المخاطر والمرونة التشغيلية على أساس زمني منتظم وبشكل مستمر؛
- 10.3.2. reliably and accurately compile and analyse risk data and Operational Risk event data, including comprehensive internal and external loss data; and, 2-3-10 تجميع وتحليل بيانات المخاطر وبيانات أحداث المخاطر التشغيلية بشكل موثوق ودقيق، بما في ذلك بيانات الخسائر الداخلية والخارجية الشاملة؛
- 10.3.3. meet all necessary reporting requirements, including internally to the Board, Senior Management and business lines, and externally to customers and relevant authorities including the Central Bank, including ad hoc reporting 3-3-10 وتلبية جميع متطلبات رفع التقارير، بما في ذلك داخلياً لمجلس الإدارة والإدارة العليا وفروع الأعمال، وخارجياً للعملاء والسلطات ذات الصلة، بما في ذلك المصرف المركزي، بما يشمل متطلبات إعداد التقارير الوقتية أثناء تعطل أو اضطراب أو أزمة جارية.

requirements during an ongoing disruption or crisis.

- 10.4. The aggregation and reporting processes must be subject to high standards of validation and periodic review by the internal audit function. 4-10 يجب أن تخضع عمليات التجميع ورفع التقارير لمعايير تحقق عالية، ومراجعة دورية من قبل وظيفة التدقيق الداخلي.
- 10.5. For an LFI that is part of a group, effective and timely risk data aggregation must not be hindered by the group structure or the jurisdictions in which subsidiaries and branches are located, or by the systems and processes used by them. 5-10 وفي حالة المنشأة المالية المرخصة التي هي جزء من مجموعة، يجب ألا يكون هيكل المجموعة أو مناطق الاختصاص التي تقع فيها الشركات التابعة والفروع، أو النظم والعمليات المستخدمة من قبلهم، عائقاً للتجميع الفعال، وفي المواقف المناسبة، لبيانات المخاطر.

Article (11): Business Continuity Planning

المادة (11): تخطيط استمرارية الأعمال

- 11.1. An LFI must maintain Business Continuity and Disaster Recovery Plans for its Critical Operations that are well-integrated into the LFI's Operational Risk and Operational Resilience framework. 1-11 يجب على المنشأة المالية المرخصة الاحتفاظ بخطط استمرارية أعمال وتعافي من الكوارث لعملياتها الحيوية. ويجب أن يتم دمجها بشكل جيد في إطار المخاطر التشغيلية والمرونة التشغيلية للمنشأة المالية المرخصة.
- 11.2. The Business Continuity and Disaster Recovery Plans must leverage and refer to the mapping of Critical Operations and related assets as required under Article 3.4 of this Regulation. 2-11 يجب على خطط استمرارية الأعمال والتعافي من الكوارث أن تستفيد من، وترجع إلى، الرسم التخطيطي للعمليات الحيوية والأصول ذات الصلة، كما هو مطلوب بموجب المادة 3-4 من هذا النظام.
- 11.3. The LFI's second and third lines of defence, in particular the Operational Risk management function and internal audit function, must regularly review the Business Continuity and Disaster Recovery Plans. This should be at least once per year for Critical Operations. 3-11 يجب على خطّي الدفاع الثاني والثالث للمنشأة المالية المرخصة، وبخاصة وظيفة إدارة المخاطر التشغيلية ووظيفة التدقيق الداخلي، مراجعة خطط استمرارية الأعمال والتعافي من الكوارث بانتظام. ويجب أن يكون ذلك مرة واحدة في السنة على الأقل بالنسبة للعمليات الحيوية.
- 11.4. The Business Continuity and Disaster Recovery Plans must identify relevant potential disruption scenarios and how these would affect the LFI's Critical Operations, taking into account internal or external interdependencies. The plans must address potential contingencies to ensure their swift implementation is not compromised, for example due to unavailability of key staff. 4-11 يجب أن تحدد خطط استمرارية الأعمال والتعافي من الكوارث سيناريوهات التعطل أو الاضطراب المحتملة ذات الصلة، وكيف ستؤثر على العمليات الحيوية للمنشأة المالية المرخصة، مع الأخذ في الاعتبار الترابطات الداخلية والخارجية. ويجب أن تعالج الخطط الطوارئ المحتملة لضمان عدم التأثير على سرعة تنفيذها، على سبيل المثال، بسبب عدم توفر موظفين رئيسيين.
- 11.5. The range of disruption scenarios must range from scenarios where a return to normal operations is possible with the same assets, to 5-11 يجب أن يتراوح نطاق سيناريوهات التعطل أو الاضطراب من سيناريوهات تكون فيها العودة إلى

- scenarios where major assets are rendered unavailable for prolonged periods or permanently without being recoverable.
- العمليات العادية ممكنة بنفس الأصول، إلى سيناريوهات تصبح فيها الأصول الجوهرية غير متاحة لفترات طويلة، أو بشكل دائم دون أن تكون قابلة للاستعادة.
- 11.6. Each scenario must be subject to a quantitative and qualitative impact assessment or a business impact analysis, distinguishing between financial, operational, legal and reputational impact.
- 6-11 يجب أن يخضع كل سيناريو لتقييم الأثر الكمي والنوعي، أو لتحليل التأثير على الأعمال، مع التمييز بين التأثير المالي والتشغيلي والقانوني وعلى السمعة.
- 11.7. Business Continuity and Disaster Recovery Plans must include clear, unambiguous triggers for their activation, such as defined thresholds for the maximum tolerable disruption or outage.
- 7-11 يجب أن تتضمن خطط استمرارية الأعمال والتعافي من الكوارث مؤشرات واضحة ولا لبس فيها لتفعيل هذه الخطط، مثل سقف محدد لأقصى تعطل أو اضطراب أو انقطاع يمكن تحمله.
- 11.8. Business Continuity and Disaster Recovery Plans must address the actions that will be taken in case of a disruption to business continuity, and establish clear, measurable targets in the form of recovery time objectives and recovery point objectives, that reflect the tolerance for disruption as approved by the Board.
- 8-11 يجب أن تتناول خطط استمرارية الأعمال والتعافي من الكوارث الإجراءات التي سيتم اتخاذها في حال انقطاع أو اضطراب استمرارية الأعمال، وتضع أهدافاً واضحة وقابلة للقياس في شكل أهداف زمنية للتعافي وأهداف نقطة التعافي، والتي تعكس درجة تحمل التعطل والاضطرابات حسبما تم اعتماده من قبل مجلس الإدارة.
- 11.9. Business Continuity and Disaster Recovery Plans must include communications guidelines and arrangements for key relevant stakeholders, including the Board, Senior Management, staff, relevant authorities including but not limited to the Central Bank, customers and the wider public, and Third-Party Service Providers.
- 9-11 يجب أن تتضمن خطط استمرارية الأعمال والتعافي من الكوارث إرشادات وترتيبات اتصال لأصحاب المصلحة الرئيسيين ذوي الصلة، بما في ذلك، مجلس الإدارة والإدارة العليا والموظفين والسلطات ذات الصلة، بما في ذلك، على سبيل المثال لا الحصر، المصرف المركزي، وكذلك العملاء والجمهور بوجه عام، ومزودي الخدمات الخارجيين.
- 11.10. Business Continuity and Disaster Recovery Plans and procedures must be reviewed and tested regularly to ensure that the recovery and resumption objectives and timeframes can be met. This must be at least annually for Critical Operations. Where relevant, testing should include key Third-Party Service Providers. The results must be reported to the Board and Senior Management.
- 10-11 يجب مراجعة واختبار خطط وإجراءات استمرارية الأعمال والتعافي من الكوارث بانتظام لضمان إمكانية تحقيق أهداف التعافي واستئناف الأعمال والأطر الزمنية. ويجب أن يكون ذلك سنوياً على الأقل بالنسبة للعمليات الرئيسية. ويجب، عند الاقتضاء، أن يشمل الاختبار مزودي الخدمات الخارجيين الرئيسيين. ويجب رفع تقارير عن النتائج إلى مجلس الإدارة والإدارة العليا.
- 11.11. An LFI must conduct Business Continuity and Disaster Recovery exercises under a range of severe but plausible scenarios to assess its
- 11-11 يجب على المنشأة المالية المرخصة أن تقوم بإجراء تمارين استمرارية أعمال وتعافٍ من الكوارث تحت مجموعة من السيناريوهات الشديدة، ولكنها معقولة،

ability to deliver Critical Operations through disruption.

لتقييم قدرتها على أداء العمليات الحيوية خلال فترات التعطل أو الاضطرابات.

Article (12): Change Management and Changes in Operations

المادة (12): إدارة التغيير والتغييرات في العمليات

- 12.1. LFIs must have a well-resourced change management process in place to proactively plan for, manage and approve Changes in Operations, including the introduction of, discontinuation of, or changes to products, activities, processes and systems.
- 12-1 يجب أن تتوفر لدى المنشأة المالية المُرخصة عملية إدارة تغيير مزودة بموارد كافية للتخطيط بشكل استباقي لإدارة واعتماد التغييرات في العمليات، بما في ذلك إدخال أو إيقاف أو إجراء تغييرات على المنتجات والأنشطة والعمليات والنظم.
- 12.2. The Operational Risk management function must be involved throughout the change management process to ensure the implementation of appropriate controls and to ensure the involvement of the relevant Control Functions.
- 12-2 يجب أن تشارك وظيفة إدارة المخاطر التشغيلية خلال عملية إدارة التغيير للتحقق من تنفيذ الضوابط الملائمة، وضمان مشاركة وظائف الضبط ذات الصلة.
- 12.3. LFIs must have change management policies and procedures that address the process for identifying, managing, challenging, approving and monitoring changes in operations, considering at a minimum:
- 12-3 يجب أن تتوفر لدى المنشآت المالية المُرخصة سياسات وإجراءات إدارة تغيير تتناول عملية تحديد وإدارة، واختبار واعتماد ومراقبة التغييرات في العمليات، مع مراعاة ما يأتي، كحد أدنى:
- 12.3.1. Inherent risks, including but not limited to legal, financial, compliance, model and ICT risks;
- 1-3-12 المخاطر المتأصلة، بما في ذلك، على سبيل المثال لا الحصر، المخاطر القانونية والمخاطر المالية ومخاطر الامتثال ومخاطر النماذج ومخاطر تقنية المعلومات والاتصال؛
- 12.3.2. Changes in the LFI's risk profile, both due to the change itself and due to its impact on other related activities, and compliance with its Risk Appetite and Tolerance;
- 2-3-12 التغييرات في ملف مخاطر المنشأة المالية المُرخصة، بسبب التغيير نفسه أو بسبب تأثيره على الأنشطة الأخرى ذات الصلة، والامتثال لتقبلها للمخاطر ودرجة تحمل المخاطر؛
- 12.3.3. Necessary controls, risk management processes and risk mitigation strategies;
- 3-3-12 الضوابط اللازمة، وعمليات إدارة المخاطر، واستراتيجيات التخفيف من المخاطر؛
- 12.3.4. Residual risk;
- 4-3-12 المخاطر المتبقية؛
- 12.3.5. Additions or changes to relevant Risk Limits or thresholds;
- 5-3-12 الإضافات أو التغييرات على سقف أو حدود المخاطر ذات الصلة؛

- 12.3.6. Procedures and metrics to measure, monitor and manage the risk of the Changes in Operations; 6-3-12 إجراءات ومعايير لقياس ومراقبة وإدارة مخاطر التغييرات في العمليات؛
- 12.3.7. The available and required capacity in terms of resources, including in particular in terms of technology infrastructure, staffing and expertise in all relevant roles, including at the level of the Board, Senior Management, and all three lines of defence; 7-3-12 القدرات المتاحة والمطلوبة من حيث الموارد، بما في ذلك بوجه خاص، من حيث البنية التحتية التكنولوجية، والموظفين والخبراء في كافة الأدوار ذات الصلة، بما في ذلك على مستوى مجلس الإدارة والإدارة العليا وجميع خطوط الدفاع الثلاثة؛
- 12.3.8. The participation and roles of the three lines of defence in the change management process; 8-3-12 مشاركة خطوط الدفاع الثلاثة وأدوارها في عملية إدارة التغيير؛
- 12.3.9. The impact and required additions or changes to the mapping of interdependencies of Critical Operations, the business continuity and disaster recovery plans, and other relevant aspects of the Operational Risk management framework; 9-3-12 التأثير والإضافات أو التغييرات المطلوبة على الرسم التخطيطي للاعتماد المتبادل بين العمليات الحيوية وخطط استمرارية الأعمال وخطط التعافي من الكوارث، وغيرها من الجوانب ذات الصلة بإطار إدارة المخاطر التشغيلية؛
- 12.3.10. The impact on risk data and systems or the scope of data that has to be captured; 10-3-12 التأثير على بيانات ونظم المخاطر، أو نطاق البيانات التي يجب جمعها أو التقاطها؛
- 12.3.11. Proactive communication with all relevant internal and external stakeholders, including, where applicable, third-party service providers; and 11-3-12 التواصل الاستباقي مع كافة أصحاب المصلحة الداخليين والخارجيين، بما في ذلك، عند الاقتضاء، مزودي الخدمات الخارجيين؛
- 12.3.12. For each of the above, how these would apply in case of urgent or emergency Changes in Operation. 12-3-12 وبالنسبة لما سبق أعلاه، كيفية تطبيقه في حالة حدوث تغييرات عاجلة أو طارئة في العمليات.
- 12.4. LFIs must monitor the changes in operations after their implementation to identify and manage any material differences to the expected Operational Risk profile. 4-12 يجب على المنشآت المالية المرخصة مراقبة التغييرات في العمليات بعد تنفيذها لتحديد وإدارة أي اختلافات جوهرية في ملف المخاطر التشغيلية المتوقع.
- 12.5. Changes in Operations that are material to Critical Operations or operations that may materially affect customers must be subject to 5-12 يجب أن تخضع التغييرات في العمليات التي تكون جوهرية بالنسبة إلى العمليات الحيوية، أو العمليات التي قد تؤثر بشكل جوهري على العملاء، لدرجة

a high degree of oversight and control measures. In this regard, LFIs must:

عالية من تدابير الإشراف والضبط. وفي هذا الصدد، يجب على المنشآت المالية المرخصة:

- | | | | |
|---------|--|--------|---|
| 12.5.1. | Ensure thorough testing of Changes in Operation prior to their implementation, and review and approval of the results by the relevant stakeholders; | 1-5-12 | التحقق من إجراء اختبار دقيق للتغييرات في العمليات قبل تطبيقها، ومراجعة واعتماد النتائج من قبل أصحاب المصلحة ذوي الصلة؛ |
| 12.5.2. | Establish plans to recover from failures during implementation, including in particular a rollback plan and, where one ICT system is replaced by another, a parallel run of the old and new systems for a predefined minimum period long enough to ensure that the new system is functional and resilient; | 2-5-12 | وضع خطط للتعافي من الإخفاقات خلال التطبيق، بما في ذلك، بوجه خاص، خطة لسحب التغييرات، وفي حال استبدال نظام تقنية المعلومات والاتصال بنظام آخر، إجراء تشغيل مواز للنظامين القديم والجديد، لمدة زمنية محددة مسبقاً وتكون طويلة بما يكفي للتحقق من أن النظام الجديد يعمل بشكل جيد ومرن؛ |
| 12.5.3. | Procure an external expert to provide independent assurance at key steps in the process, including a report assessing the proposed Changes in Operations and the change management controls and measures; | 3-5-12 | التعاقد مع خبير خارجي لتقديم تأكيد مستقل في مراحل رئيسية من العملية، بما في ذلك تقريراً يقيم التغييرات المقترحة في العمليات، وضوابط وتدابير إدارة التغيير؛ |
| 12.5.4. | Senior Management is responsible to review, endorse and respond to the external expert report prior to providing the report to the Central Bank; | 4-5-12 | تكون الإدارة العليا مسؤولة عن مراجعة ومصادقة تقرير الخبير الخارجي والرد عليه، قبل تزويد المصرف المركزي بالتقرير؛ |
| 12.5.5. | Notify the Central Bank and provide it with the external expert's report at a minimum 30 calendar days prior to the proposed implementation of the Changes in Operation; and | 5-5-12 | إخطار المصرف المركزي وتزويده بتقرير الخبير الخارجي، قبل 30 يوماً تقويمياً على الأقل من تنفيذ التغييرات في العمليات؛ |
| 12.5.6. | Obtain the written no-objection of the Central Bank prior to implementation of the Changes in Operation. | 6-5-12 | والحصول على عدم ممانعة كتابية من المصرف المركزي قبل الشروع في تنفيذ التغييرات في العمليات. |
| 12.6. | LFIs must ensure that their customers are not negatively affected by changes in their operations. In particular, where Changes in Operations result in material erroneous information being provided to customers, such as payment confirmations, debit or credit | 6-12 | يجب على المنشآت المالية المرخصة التحقق من عدم تأثر عملائها سلباً بالتغييرات في عملياتها. وبصفة خاصة، عندما تؤدي التغييرات في العمليات إلى تقديم معلومات جوهرية خاطئة للعملاء، مثل تأكيدات الدفع، أو معاملات الإضافة |

transactions and balances, LFIs must provide customers with clear information on how their accounts or transactions were affected as a result, including as part of efforts to address the errors. LFIs are liable for any damages incurred by the customer due to the LFI's error, consistent with the Central Bank's consumer protection regulations.

أو الخصم، والأرصدة الدائنة والمدينة، فيجب على المنشآت المالية المرخصة تزويد العملاء بمعلومات واضحة حول كيفية تأثر حساباتهم أو معاملاتهم نتيجة لذلك، بما في ذلك كجزء من الجهود المبذولة لمعالجة الأخطاء. وتحمل المنشآت المالية المرخصة المسؤولية عن أي أضرار يتكبدها العميل بسبب خطأ المنشأة المالية المرخصة، بما يتوافق مع أنظمة حماية المستهلك الصادرة عن المصرف المركزي.

Article (13): Third Party Risk Management

المادة (13): إدارة مخاطر مزودي الخدمات الخارجيين

- 13.1. LFIs must have a Board-approved strategy and associated policies and processes for the assessment, monitoring and management of third-party risk, integrated into their Operational Risk management framework.
- 13.2. As a general principle, LFIs must not overly rely on Outsourcing and maintain sufficient staff, expertise, and resources of its own to effectively perform and manage the activities for which it is licensed.
- 13.3. An LFI must not enter into an arrangement with a Third-Party Service Provider without first performing a risk assessment of the arrangement and conducting appropriate due diligence on the Third-Party Service Provider.
- 13.4. For arrangements that relate to or have an impact on Critical Operations, the LFI must verify that the Third-Party Service Provider has at least an equivalent level of Operational Resilience to safeguard the Critical Operations in both normal circumstances and in the event of disruption.
- 13.5. An LFI must obtain a notice of non-objection from the Central Bank prior to Outsourcing any activity that has the potential, if disrupted, to have a significant impact on the LFI's Critical Operations.
- 13.6. Third-Party Service Provider arrangements must be governed by legally binding, written contracts that clearly set out the rights and
- 1-13 يجب أن تكون لدى المنشآت المالية المرخصة استراتيجية معتمدة من مجلس الإدارة، وسياسات وعمليات مرتبطة بها، لأغراض تقييم ومراقبة وإدارة مخاطر مزودي الخدمات الخارجيين، مدمجة في إطار إدارة المخاطر التشغيلية.
- 2-13 كمبدأ عام، يجب على المنشآت المالية المرخصة عدم الاعتماد بشكل مفرط على التعميد، بل الحفاظ على عدد كافٍ من الموظفين والخبرات والموارد الخاصة بها لضمان أداء وإدارة الأنشطة التي رُخصوا لها، بشكل فعال.
- 3-13 لا يجوز للمنشأة المالية المرخصة الدخول في ترتيبات مع مزود خدمة خارجي قبل القيام أولاً بإجراء تقييم مخاطر هذه الترتيبات، وتطبيق إجراءات عناية واجبة ملائمة بشأن مزود الخدمة الخارجي.
- 4-13 بالنسبة للترتيبات المتعلقة بالعمليات الحيوية أو التي تؤثر عليها، يجب على المنشأة المالية المرخصة التحقق من أن لدى مزود الخدمة الخارجي مستوى مكافئاً من المرونة التشغيلية على الأقل، لحماية العمليات الحيوية في الظروف العادية وفي حالة حدوث تعطل أو اضطراب.
- 5-13 يجب على المنشأة المالية المرخصة الحصول على إشعار بعدم الممانعة من المصرف المركزي قبل تعهد أي نشاط تكون لديه، في حال تعطله أو حدوث اضطراب فيه، إمكانية إحداث تأثير كبير على العمليات الحيوية للمنشأة المالية المرخصة.
- 6-13 يجب أن تخضع ترتيبات مزود الخدمة الخارجي لعقود كتابية ملزمة قانوناً، تحدد بوضوح حقوق والتزامات ومسؤوليات وتوقعات جميع الأطراف في

obligations, responsibilities and expectations of all parties to the arrangement, including regarding ownership and confidentiality of data and termination rights, and, for arrangements that relate to or have an impact on the LFI's Critical Operations, the LFI's right to inspect the Third-Party Service Provider's records, to request and receive reporting such as audit and risk reports.

الترتيبات، بما في ذلك فيما يتعلق بملكية وسرية البيانات، وحقوق الإنهاء، وبالنسبة للترتيبات التي تتعلق بالعمليات الحيوية للمنشأة المالية المُرخّصة أو تؤثر عليها، حق المنشأة المالية المُرخّصة في فحص سجلات مزود الخدمة الخارجي، وطلب واستلام التقارير، مثل تقارير التدقيق والمخاطر.

- 13.7. The contract must include a requirement for the Third-Party Service Provider to comply with Central Bank requests and requirements, including notification and reporting requirements and, for Outsourcing arrangements that could impact the LFI's Critical Operations, the right of the Central Bank to conduct on-site examinations related to the services they provide to the LFI.
- 7-13 يجب أن يتضمن العقد إلزامًا لمزود الخدمة الخارجي بالامتثال لطلبات ومتطلبات المصرف المركزي، بما في ذلك متطلبات الإخطار ورفع التقارير، وبالنسبة لترتيبات التعهيد التي قد تؤثر على العمليات الحيوية للمنشأة المالية المُرخّصة، حق المصرف المركزي في إجراء عمليات تفتيش ميداني تتعلق بالخدمات التي يقدمها للمنشأة المالية المُرخّصة.
- 13.8. For arrangements that involve or may involve the LFI's or its customers' data being shared by the Third-Party Service Provider with further subcontractors, the provisions of Articles 13.6 and 13.7 above must apply and be legally enforceable through contract against those subcontractors.
- 8-13 بالنسبة للترتيبات التي تنطوي أو قد تنطوي على مشاركة بيانات المنشأة المالية المُرخّصة أو عملائها من قبل مزود الخدمة الخارجي مع متعهدين فرعيين آخرين، يجب تطبيق أحكام المادتين 13-6 و 13-7 أعلاه وأن تكون قابلة للتنفيذ قانونًا من خلال عقد، ضد أولئك المتعهدين الفرعيين.
- 13.9. An LFI must maintain adequate resources to manage and monitor Third-Party Service arrangements, and its internal control system must address the related control measures, including at a minimum:
- 9-13 يجب على المنشأة المالية المُرخّصة الاحتفاظ بموارد كافية لإدارة ومراقبة ترتيبات الخدمات المقدمة من مزودي الخدمات الخارجيين، ويجب أن يتناول نظام الضوابط الداخلية الخاص بها تدابير الضوابط ذات الصلة، بما في ذلك، كحد أدنى:
- 13.9.1. Maintaining an updated register of Outsourced activities and Third-Party Service arrangements relating to Critical Operations;
- 1-9-13 الاحتفاظ بسجل محدّث للأنشطة المعهّد بها لمزودي الخدمات الخارجيين، وترتيبات الخدمات المقدمة من قبل مزودي الخدمات الخارجيين المتعلقة بالعمليات الحيوية؛
- 13.9.2. Metrics to measure and monitor performance and risks related to Third-Party Service arrangements on an ongoing basis;
- 2-9-13 مؤشرات لقياس ومراقبة الأداء والمخاطر ذات الصلة بترتيبات الخدمات المقدمة من مزودي الخدمات الخارجيين، على أساس مستمر؛
- 13.9.3. Assessments of and reporting on the performance of and risks related to Third-Party Service Provider arrangements on an ongoing basis,
- 3-9-13 تقييمات ورفع تقارير بشأن أداء ترتيبات الخدمة المقدمة من مزودي الخدمات الخارجيين والمخاطر المتعلقة بها على

- including the financial condition of Third-Party Service Providers; and
- أساس مستمر، بما في ذلك الوضع المالي لمزودي الخدمات الخارجيين؛
- 13.9.4. Management of dependencies on Third-Party Service Provider arrangements for Critical Operations.
- 13-9-4 وإدارة حالات الاعتماد على ترتيبات الخدمات التي يقدمها مزودي الخدمات الخارجيين فيما يتعلق بالعمليات الحيوية.
- 13.10. Within its Operational Risk and Operational Resilience framework, an LFI must address any reliance on Third-Party Service Providers, in particular in its Business Continuity Plan, and in its mapping of assets and resources related to Critical Operations.
- 10-13 يجب على المنشأة المالية المرخصة، في إطار المخاطر التشغيلية والمرونة التشغيلية، أن تعالج أي اعتماد على مزودي الخدمات الخارجيين، وخاصة في خطة استمرارية الأعمال، وفي الرسم التخطيطي للأصول والموارد المتعلقة بالعمليات الحيوية.
- 13.11. An LFI must maintain viable contingency and exit plans for its Third-Party Service Provider arrangements that are material to its Critical Operations.
- 11-13 يجب على المنشأة المالية المرخصة أن تحتفظ بخطة طوارئ وخروج قابلة للتطبيق فيما يخص ترتيبات مزودي الخدمات الخارجيين التي تعتبر هامة لعملياتها الحيوية.
- In particular, such plans must demonstrate the LFI's Operational Resilience in the event of a failure or disruption at a Third-Party Service Provider impacting the provision of Critical Operations.
- وعلى وجه الخصوص، يجب أن تثبت هذه الخطط المرونة التشغيلية للمنشأة المالية المرخصة في حالة حدوث إخفاق أو تعطل أو اضطراب لدى مزود خدمة خارجي يؤثر على أداء العمليات الحيوية.
- The Business Continuity Plan must assess the substitutability of arrangements with Third-Party Service Providers, highlighting any instances where a sufficiently timely substitution of the Third-Party Service Provider, including by the LFI itself, is very costly, carries high risks, or is impossible.
- يجب أن تقيم خطة استمرارية الأعمال إمكانية استبدال الترتيبات مع مزودي الخدمات الخارجيين، مع تسليط الضوء على أي حالات يكون فيها استبدال مزود الخدمة الخارجي في الوقت المناسب، بما في ذلك من قبل المنشأة المالية المرخصة نفسها، مكلفاً للغاية، أو ينطوي على مخاطر عالية، أو مستحيل التنفيذ.
- 13.12. The Central Bank may, at its discretion, require the discontinuation of one or more arrangements with a Third-Party Service Provider or the discontinuation of a Critical Operation that is overly reliant on one or more arrangements with Third-Party Service Providers.
- 12-13 للمصرف المركزي، وفقاً لتقديره، أن يطلب إيقاف واحد أو أكثر من الترتيبات مع مزود خدمة خارجي، أو إيقاف عملية حيوية تعتمد بشكل مفرط على ترتيب واحد أو أكثر مع مزودي خدمات خارجيين.

Article (14): Shari'ah Non-Compliance Risk

المادة (14): مخاطر عدم الامتثال لأحكام الشريعة

- 14.1. An Islamic Finance Institution must have in place adequate systems and controls, including the implementation of a Shari'ah
- 1-14 يجب أن تكون لدى المؤسسة المالية الإسلامية نظم وضوابط كافية، بما في ذلك تطبيق إطار حوكمة شرعية، وضمان الامتثال لقرارات الهيئة العليا

governance framework, and ensure compliance with the Higher Shari'ah Authority's resolutions. This includes policies and procedures for the approval of Islamic finance products, contracts and activities.

الشرعية. ويشمل ذلك السياسات والإجراءات الخاصة بالموافقة على منتجات وعقود وأنشطة التمويل الإسلامي.

- 14.2. An Islamic Financial Institution must have in place an appropriate framework, adequate systems, controls and limits for Shari'ah Non-Compliance Risk management, that are comprehensive and address the specific risks associated with Shari'ah compliant businesses and activities, including Shari'ah Non-Compliance Risk and risks related to its fiduciary responsibilities.
- 2-14 يجب أن يكون لدى المؤسسة المالية الإسلامية إطار مناسب ونظم وضوابط وحدود كافية لإدارة مخاطر عدم الامتثال لأحكام الشريعة، والتي تكون شاملة وتعالج المخاطر المحددة المرتبطة بالأعمال والأنشطة المتوافقة مع أحكام الشريعة، بما في ذلك مخاطر عدم الامتثال لأحكام الشريعة والمخاطر المتعلقة بمسؤولياتها الائتمانية.
- 14.3. An Islamic Finance Institution must understand and test the interlinkages and impacts of Shari'ah Non-Compliance Risk on other risks throughout the life cycle of the contract, including formation, termination and any other aspects that affect the contract's performance, such as fraud and misrepresentation.
- 3-14 يجب على المؤسسة المالية الإسلامية أن تفهم وتختبر الارتباطات المتبادلة وتأثيرات مخاطر عدم الامتثال لأحكام الشريعة على المخاطر الأخرى طوال مدة العقد، بما في ذلك صياغة وإنهاء العقد وأي جوانب أخرى تؤثر على الوفاء به، مثل الاحتيال وتقديم معلومات مضللة.
- 14.4. An Islamic Finance Institution must maintain a formal record of income not recognized arising from Shari'ah Non-Compliance and report this regularly to the internal Shari'ah supervision committee.
- 4-14 يجب على المؤسسة المالية الإسلامية الاحتفاظ بسجل رسمي للدخل غير المعترف به الذي ينشأ عن عدم الامتثال لأحكام الشريعة، والإبلاغ عنه بانتظام إلى لجنة الرقابة الشرعية الداخلية.
- 14.5. The risk management function must proactively identify potential risk areas of Shari'ah non-compliance, evaluate the likelihood and severity of Shari'ah non-compliance events occurring, identify any profits that may not be recognized as eligible Islamic finance profits, and disclose these findings to the internal Shari'ah supervision committee.
- 5-14 يجب على وظيفة إدارة المخاطر أن تحدد بشكل استباقي مجالات المخاطر المحتملة لعدم الامتثال لأحكام الشريعة، وتقييم احتمالية وقوع حالات عدم امتثال لأحكام الشريعة وشدتها، وتحديد أي أرباح قد لا يتم الاعتراف بها كأرباح تمويل إسلامي مؤهلة، والإفصاح عن هذه النتائج للجنة الرقابة الشرعية الداخلية.

Where such Shari'ah Non-Compliance Risk materializes, the Islamic Finance Institution must review the adequacy and, where necessary, improve its internal control framework related to Shari'ah Non-Compliance Risk. The internal Shari'ah supervision committee is the body who has the authority to determine whether a Shari'ah

وفي حال تحقق مخاطر عدم الامتثال لأحكام الشريعة، يجب على المؤسسة المالية الإسلامية مراجعة كفاية إطار الضوابط الداخلية المتعلق بمخاطر عدم الامتثال لأحكام الشريعة، وتحسينه عند الضرورة. ولجنة الرقابة الشرعية الداخلية هي الهيئة التي لديها السلطة لتحديد ما إذا كانت

Non-Compliance Risk has materialized or not. مخاطر عدم الامتثال لأحكام الشريعة قد تحققت أم لا.

- 14.6. An Islamic Finance Institution must manage risk in accordance with accepted Shari'ah principles, and in accordance with the level and type of risk allocated to it pursuant to contracts entered into with its customers. An Islamic Finance Institution must not seek to circumvent risk it has contractually acceded to (including asset and ownership risk). Such risk may however be mitigated under the direction of the internal Shari'ah supervision committee. يجب على المؤسسة المالية الإسلامية إدارة المخاطر وفقاً لمبادئ الشريعة المقبولة، ووفقاً لمستوى ونوع المخاطر المخصصة لها بموجب العقود المبرمة مع عملائها. ولا يجوز للمؤسسة المالية الإسلامية أن تسعى إلى الالتفاف على المخاطر التي قبلتها بموجب العقد (بما في ذلك مخاطر الأصول والملكية). ومع ذلك، يمكن التخفيف من مثل هذه المخاطر تحت إشراف لجنة الرقابة الشرعية الداخلية.
- 14.7. An Islamic Finance Institution must maintain separate accounts in respect of the IFI's operations, for restricted and unrestricted investment accounts, Takaful funds or any other funds that are attributed to specific clients under different contracts and ensure proper allocation of expenses, recognition of profit or loss and must maintain records for all relevant transactions. يجب على المؤسسة المالية الإسلامية الاحتفاظ بحسابات منفصلة حول عمليات المؤسسة المالية الإسلامية فيما يتعلق بحسابات الاستثمار المقيدة وغير المقيدة، وصناديق التكافل أو أي أموال أخرى تُنسب إلى عملاء محددين بموجب عقود مختلفة، وضمان التعامل السليم مع تخصيص النفقات، والاعتراف بالربح أو الخسارة، ويجب عليها الاحتفاظ بسجلات لجميع المعاملات ذات الصلة.

Article (15): Notification and Reporting Requirements

المادة (15): متطلبات الإبلاغ ورفع التقارير

- 15.1. An LFI must promptly notify the Central Bank when it becomes aware of a significant deviation from its Board-approved Operational Risk Appetite statement, policies or procedures, including the Board-approved tolerance for disruption, or becomes aware that a material Operational Risk has not been adequately addressed. يجب على المنشأة المالية المرخصة إبلاغ المصرف المركزي على الفور عندما تعلم بوجود انحراف كبير عن بيان تقبل المخاطر التشغيلية أو السياسات أو الإجراءات المعتمدة من مجلس الإدارة، بما في ذلك درجة تحمل التعطل والاضطراب المعتمدة من مجلس الإدارة، أو عندما تدرك أن مخاطر تشغيلية جوهرية لم تتم معالجتها بشكل كافٍ.
- 15.2. An LFI must notify the Central Bank of any Operational Risk events that significantly impact or may significantly impact the continuity or integrity of Critical Operations. This includes in particular any event that triggers, or is likely to trigger its business continuity or disaster recovery plans, or has, or is likely to have, a material impact on the LFI's customers, operations, profitability or capital. يجب على المنشأة المالية المرخصة إخطار المصرف المركزي بأي أحداث مخاطر تشغيلية تؤثر بشكل كبير، أو قد تؤثر بشكل كبير، على استمرارية وسلامة العمليات الحيوية. ويشمل ذلك بوجه خاص أي حدث يؤدي إلى، أو من المرجح أن يؤدي إلى، تفعيل خطط استمرارية الأعمال أو التعافي من الكوارث، أو له، أو من المرجح أن يكون له، تأثير ملموس على عملاء المنشأة المالية المرخصة أو عملياتها أو ربحيتها أو رأس مالها.

In particular, the LFI must:

وبوجه خاص، يجب على المنشأة المالية المرخصة:

- 15.2.1. Within 4 hours: notify the Central Bank of the events, including what Critical Operations are affected; 1-2-15 في غضون 4 ساعات: إخطار المصرف المركزي بالأحداث، بما في ذلك إيضاح العمليات الحيوية المتأثرة؛
- 15.2.2. Within 24 hours: provide the Central Bank with a summary report of the nature of the event, the actions being taken, the likely impact and the timeframe for returning to normal operations; 2-2-15 في غضون 24 ساعة: تزويد المصرف المركزي بتقرير موجز حول طبيعة الحدث، والإجراءات التي يتم اتخاذها، والتأثير المحتمل، والإطار الزمني للعودة إلى العمليات العادية؛
- 15.2.3. Upon return to normal operations: notify the Central Bank upon returning to normal operations; and 3-2-15 عند العودة إلى العمليات العادية: إخطار المصرف المركزي عند استئناف العمليات العادية؛
- 15.2.4. Any other notifications, information requirements and timeframes as specified by the Central Bank on a case-by-case basis. 4-2-15 وأي إخطارات أخرى، ومتطلبات معلومات، وأطر زمنية يحددها المصرف المركزي على أساس كل حالة على حدة.
- 15.3. An LFI must notify the Central Bank within 72 hours of any high-risk Incident. The criteria for categorisation of an Incident as high risk must be defined in Board-approved policies. 3-15 يجب على المنشأة المالية المرخصة إخطار المصرف المركزي في غضون 72 ساعة من وقوع أي حادث عالي الخطورة. ويجب تحديد معايير تصنيف الحادث على أنه عالي الخطورة في السياسات المعتمدة من مجلس الإدارة.
- 15.4. An LFI must provide, upon request, any specific information with respect to Operational Risk that the Central Bank may require. 4-15 يجب على المنشأة المالية المرخصة أن تقدم، عند الطلب، أي معلومات محددة فيما يتعلق بالمخاطر التشغيلية قد يطلبها المصرف المركزي.
- 15.5. An LFI must comply with regular reporting requirements on Operational Risk and Operational Resilience as prescribed by the Central Bank. 5-15 يجب على المنشأة المالية المرخصة الامتثال لمتطلبات رفع التقارير المنتظمة بشأن المخاطر التشغيلية والمرونة التشغيلية كما يحددها المصرف المركزي.
- 15.6. An LFI must comply with the notification requirements which the Central Bank may set and vary from time to time. The Central Bank will inform LFIs of such changes through a notice. 6-15 يجب على المنشأة المالية المرخصة الامتثال لمتطلبات الإخطار التي قد يحددها المصرف المركزي والتي تختلف من وقت لآخر. وسيبلغ المصرف المركزي المنشآت المالية المرخصة بهذه التغييرات من خلال إشعار.

Article (16): Disclosure Requirements

المادة (16): متطلبات الإفصاح

- 16.1. An LFI must have a policy on public disclosures related to Operational Risk and 1-16 يجب أن تكون لدى المنشأة المالية المرخصة سياسة بشأن الإفصاحات العامة المتعلقة بالمخاطر التشغيلية

associated internal controls setting out how it determines what information is disclosed and what information should not be disclosed.

والضوابط الداخلية المرتبطة بها والتي تحدد كيفية تحديد المعلومات التي يتم الكشف عنها والمعلومات التي لا ينبغي الكشف عنها.

- 16.2. An LFI must publicly disclose key information about its approach to Operational Risk and Operational Resilience management, and its Operational Risk exposure, commensurate with its size, risk profile, the complexity of its operations, its systemic importance and role in the financial system, and evolving industry practices.
- 16.3. The disclosed information must allow stakeholders to assess to which extent the LFI identifies, assesses, monitors, controls and mitigates Operational Risk effectively.
- 16.4. The disclosed information must provide insight into the practices of the LFI with regard to the protection of Personal Data.
- 16.5. LFIs that are branches or subsidiaries of foreign firms with a similar license may largely rely on the disclosures of the group they belong to, but must publish at least a summary of the Operational Risk management framework in place for their UAE operations on their public website.
- 16.6. LFIs that are subsidiaries of other LFIs in the UAE may largely rely on the disclosures of the group they belong to, but the group disclosures must sufficiently address the disclosures required for the LFI.
- 2-16 يجب على المنشأة المالية المرخصة الإفصاح علناً عن المعلومات الرئيسية حول منهجيتها في إدارة المخاطر التشغيلية والمرونة التشغيلية، وتعرضها للمخاطر التشغيلية، بما يتناسب مع حجم أعمالها وملف مخاطرها ودرجة تعقد عملياتها، وأهميتها النظامية، ودورها في النظام المالي وممارسات الصناعة المتغيرة.
- 3-16 يجب أن تتيح المعلومات المفصّل عنها لأصحاب المصلحة إمكانية تقييم مدى فعالية تحديد المنشأة المالية المرخصة للمخاطر التشغيلية وتقييمها ومراقبتها وضبطها وتخفيفها.
- 4-16 يجب أن توفر المعلومات المفصّل عنها فهماً أعمق لممارسات المنشأة المالية المرخصة فيما يتعلق بحماية البيانات الشخصية.
- 5-16 يجوز للمنشآت المالية المرخصة التي هي فروع أو شركات تابعة لشركات أجنبية لديها ترخيص مماثل، الاعتماد إلى حد كبير على إفصاحات المجموعة التي تنتمي إليها، ولكن يجب عليها نشر ملخص على الأقل لإطار إدارة المخاطر التشغيلية المعمول به لعملياتها في دولة الإمارات العربية المتحدة، على موقعها الإلكتروني العام.
- 6-16 يجوز للمنشآت المالية المرخصة التي هي شركات تابعة لمنشآت مالية مرخصة أخرى في دولة الإمارات العربية المتحدة الاعتماد إلى حد كبير على إفصاحات المجموعة التي تنتمي إليها، ولكن يجب أن تتناول إفصاحات المجموعة، بشكل كافٍ، الإفصاحات المطلوبة للمنشأة المالية المرخصة.

Article (17): Enforcement & Sanctions

المادة (17): الإنفاذ والعقوبات

- 17.1. Violation of any provision of this regulation and any accompanying Standards may be subject to supervisory action and administrative & financial sanctions as deemed appropriate by the Central Bank.
- 17.2. Supervisory action and administrative & financial sanctions by the Central Bank may
- 1-17 تخضع المخالفة لأي من أحكام هذا النظام وأي معايير مصاحبة له إلى الإجراءات الرقابية والعقوبات الإدارية والمالية التي يراها المصرف المركزي ملائمة.
- 2-17 قد تتضمن الإجراءات الرقابية والعقوبات الإدارية والمالية التي يتخذها المصرف المركزي سحب أو

include withdrawing, replacing or restricting the powers of Senior Management or members of the Board, providing for the interim management of the LFI, imposition of fines or barring individuals from the UAE financial sector.

استبدال أو تقييد صلاحيات الإدارة العليا أو أعضاء مجلس الإدارة، أو إجراء ترتيبات للإدارة المؤقتة للمنشأة المالية المرخصة، أو فرض غرامات، أو حظر أفراد من القطاع المالي بدولة الإمارات العربية المتحدة.

Article (18): Interpretation of Regulation

المادة (18): تفسير النظام

The Regulatory Development Department of the Central Bank shall be the reference for interpretation of the provisions of this regulation.

تكون إدارة تطوير الأنظمة الرقابية بالمصرف المركزي هي المرجع لتفسير أحكام هذا النظام.

Article (19): Cancellation of Previous Notices

المادة (19): إلغاء إشعارات سابقة

This regulation cancels and replaces the following Central Bank Circulars and Notices:

يُلغى هذا النظام ويحل محل تعاميم وإشعارات المصرف المركزي الآتية:

19.1. Circular No. 163/2018, the 'Operational Risk Regulation' and the 'Operational Risk Standards' issued on 29 August 2018.

1-19 التعميم رقم 163/2018، "نظام المخاطر التشغيلية" و"معايير المخاطر التشغيلية"، الصادر بتاريخ 29 أغسطس 2018.

Article (20): Publication & Effective Date

المادة (20): النشر وتاريخ النفاذ

20.1. This regulation shall be published in the Official Gazette in both Arabic and English and shall come into effect one month from the date of publication.

1-20 يُنشر هذا النظام في الجريدة الرسمية باللغتين العربية والإنجليزية، ويدخل حيز التنفيذ بعد شهر واحد من تاريخ النشر.

خالد محمد بالعمى
محافظ مصرف الإمارات العربية المتحدة المركزي
Khaled Mohamed Balama
Governor of the Central Bank of the UAE

Annex 1

Examples of tools used for identifying and assessing Operational Risk

a. **Event management** – A pre-determined set of processes followed when an LFI experiences an Operational Risk event, including the processes of identification, analysis, end-to-end management and reporting of the event. These processes include analysis of events to understand the underlying causes and control weaknesses, the identification of new Operational Risks, and the formulation of an appropriate response to prevent, mitigate or control similar events. The outcomes are an input to the self-assessment and in particular to the assessment of control effectiveness.

b. **Internal Operational Risk event data collection and analysis** – Internal operational loss data provides meaningful information for assessing an LFI's exposure to Operational Risk and the effectiveness of internal controls. Analysis of loss events can provide insight into the causes of large losses and information on whether control failures are isolated or systematic. The data and analysis should also cover near misses and generally aim to capture risk exposures, not only those that result in financial losses. An LFI may also find it useful to capture and monitor Operational Risk contributions to credit, market and other financial risk related losses in order to obtain a more complete view of its Operational Risk exposure.

c. **External Operational Risk event data collection and analysis** – External data elements consist of gross operational loss amounts, dates, recoveries and relevant causal information for operational loss events occurring at organizations other than the LFI. External loss data can be compared with internal loss data, or used to explore possible weaknesses in the control environment or

الملحق 1

أمثلة للأدوات المستخدمة في تحديد وتقييم المخاطر التشغيلية

أ. **إدارة الأحداث** - مجموعة من العمليات المحددة مسبقاً التي يتم اتباعها عند مواجهة المنشأة المالية المرخصة لحدث مخاطر تشغيلية، وتشمل العمليات التي يتم من خلالها تحديد الحدث وتحليله وإدارته الشاملة ورفع التقارير بشأنه. وتشمل هذه العمليات تحليل الأحداث لفهم الأسباب التي أدت إليها ونقاط ضعف الضوابط، وتحديد المخاطر التشغيلية الجديدة، وصياغة استجابة ملائمة لتجنب أو تخفيف أو السيطرة على أحداث مماثلة. وتُعدّ النتائج مدخلات للتقييم الذاتي، وخاصةً لتقييم فعالية الضوابط.

ب. **جمع وتحليل بيانات أحداث المخاطر التشغيلية الداخلية** - توفر بيانات الخسائر التشغيلية الداخلية معلومات مفيدة لتقييم تعرض المنشأة المالية المرخصة للمخاطر التشغيلية، وفعالية الضوابط الداخلية. كما أن من الممكن لتحليل أحداث الخسائر أن يوفر فهماً أعمق لأسباب الخسائر الكبيرة، ومعلومات حول ما إذا كانت حالات إخفاق الضوابط معزولة أم نظامية. وينبغي أن تغطي البيانات والتحليلات أيضاً الحوادث التي كادت أن تتحقق، وأن تهدف بشكل عام إلى رصد التعرضات للمخاطر، وليس فقط تلك التي تنجم عنها خسائر مالية. وقد تجد المنشأة المالية المرخصة أيضاً أن المفيد رصد ومراقبة مساهمات المخاطر التشغيلية في الخسائر المتعلقة بمخاطر الائتمان، والسوق، وغيرها من الخسائر المتعلقة بالمخاطر المالية، وذلك للحصول على رؤية أشمل لتعرضها للمخاطر التشغيلية.

ج. **جمع وتحليل بيانات أحداث المخاطر التشغيلية الخارجية** - تتألف عناصر البيانات الخارجية من إجمالي مبالغ الخسائر التشغيلية، وتواريخها، وعمليات الاسترداد، والمعلومات السببية ذات الصلة لأحداث الخسائر التشغيلية التي تحدث في مؤسسات أخرى غير المنشأة المالية المرخصة. ويمكن مقارنة بيانات الخسائر الخارجية ببيانات الخسائر الداخلية، أو استخدامها لاستكشاف نقاط الضعف المحتملة في

consider previously unidentified risk exposures. Such data may be informative of risks that are common across the industry, or that are rare but have a high impact.

- d. **Self-assessments** – the LFI performs a self-assessment of its Operational Risks and controls on various levels, typically evaluating the inherent risk (assessing the risk before controls are considered), the effectiveness of the control environment, and the resulting residual risk (the risk exposure after controls are considered), based on both quantitative and qualitative elements.

Qualitative elements may include consideration of both the likelihood and the consequences of the risk event when determining the inherent and the residual ratings.

Assessments typically rely on process mapping to identify all key steps and dependencies in the processes, and any associated risks or areas with weaker controls in place.

The assessments should contain sufficiently detailed information on the business environment, Operational Risks, underlying causes, controls and evaluation of control effectiveness to enable an independent reviewer to determine how the LFI reached its ratings.

A risk register collates this information to form a meaningful view of the overall effectiveness of controls and to facilitate oversight by the Board, Senior Management and other internal stakeholders.

- e. **Business process mapping** – business process maps identify the key steps in business processes, activities and organizational functions. They also identify the key risk points in the overall business process. Process maps can reveal individual risks, risk interdependencies and areas of control or risk management weakness. They

بيئة الضبط، أو لدراسة تعرضات مخاطر لم تُحدد مسبقاً. وقد تُفيد هذه البيانات في تحديد المخاطر الشائعة في جميع مؤسسات القطاع، أو تلك النادرة ولكنها ذات تأثير كبير.

د. **التقييمات الذاتية** – تقوم المنشأة المالية المُرخصة بإجراء تقييم ذاتي لمخاطرها التشغيلية وضوابطها على مستويات مختلفة، وغالباً ما تُقيّم المخاطر الكامنة (تقييم المخاطر قبل الأخذ بالضوابط في الاعتبار)، وفعالية بيئة الضبط، والمخاطر المتبقية الناتجة (التعرض للمخاطر بعد الأخذ بالضوابط في الاعتبار)، استناداً إلى عناصر كمية ونوعية معاً.

قد تتضمن العناصر النوعية الأخذ في الاعتبار باحتمالية وعواقب حدث المخاطر، عند تحديد التصنيفات الكامنة والمتبقية.

تعتمد التقييمات، في الغالب، على الرسم التخطيطي للعمليات لتحديد جميع الخطوات الرئيسية والتبعيات في العمليات، وأي مخاطر مصاحبة، أو أماكن وجود ضوابط ضعيفة.

يجب أن تتضمن التقييمات معلومات مفصلة بدرجة كافية عن بيئة العمل، والمخاطر التشغيلية، والأسباب الكامنة، والضوابط، وتقييم فعالية الضوابط، لتمكين مُراجع مستقل من تحديد كيفية توصّل المنشأة المالية المُرخصة إلى تقييماتها.

يجمع سجل المخاطر هذه المعلومات لتكوين رؤية واضحة للفعالية العامة للضوابط، ولتسهيل الإشراف من قِبل مجلس الإدارة والإدارة العليا وأصحاب المصلحة الداخليين الآخرين.

هـ. **تخطيط عمليات الأعمال** – تُحدد مخططات عمليات الأعمال الخطوات الرئيسية في عمليات الأعمال، والأنشطة والوظائف التنظيمية. كما تُحدد نقاط المخاطر الرئيسية في عملية الأعمال ككل. كما تكشف مخططات العمليات عن المخاطر الفردية، والاعتماد المتبادل بينها، وأماكن وجود ضعف في

can help prioritize subsequent management action.

- f. **Control monitoring and assurance framework** – Incorporating an appropriate control monitoring and assurance framework facilitates a structured approach to the evaluation, review and ongoing monitoring and testing of key controls. The analysis of controls ensures these are suitably designed for the identified risks and operating effectively. The analysis should also consider the sufficiency of control coverage, including adequate prevention, detection and response strategies. The control monitoring and testing should be appropriate for the different Operational Risks and key controls across business areas.

- g. **Risk and performance indicators** – risk and performance indicators are risk metrics and/or statistics that provide insight into an LFI's risk exposure. Risk indicators provide insight into the status of operational processes, which in turn may provide insight into operational weaknesses, failures and potential losses. Risk and performance indicators are often paired with escalation triggers to warn when risk levels approach or exceed thresholds or limits and prompt mitigation plans.

Monitoring metrics and related trends through time against agreed thresholds or limits provides valuable information for risk management and reporting purposes, and may provide early warning information on the performance of the business and the control environment.

- h. **Scenario analysis** – Scenario analysis is a method to identify, analyse and measure a range of scenarios, including low probability and high severity events, some of which could result in severe Operational Risk losses. Scenario analysis typically involves workshop meetings of subject matter experts including senior management, business management and senior Operational Risk

الضوابط أو إدارة المخاطر. كما تُساعد في تحديد أولويات الإجراءات اللاحقة من قبل الإدارة.

و. **إطار مراقبة الضوابط والتدقيق عليها** – يمكن لدمج إطار عمل مناسب لمراقبة الضوابط والتدقيق عليها، أن يسهّل اتباع منهجية منظّمة لتقييم الضوابط الرئيسية ومراجعتها ومراقبتها بشكل مستمر. ويضمن تحليل الضوابط أن هذه الضوابط قد تم تصميمها بشكل ملائم لمواجهة المخاطر المحددة، وتعمل بشكل فعال. كما ينبغي أن يُراعى التحليل مدى كفاية تغطية الضوابط، بما في ذلك استراتيجيات الوقاية والكشف والاستجابة الكافية. ويجب أن تكون مراقبة واختبار الضوابط ملائمة لمختلف المخاطر التشغيلية والضوابط الرئيسية في مختلف قطاعات الأعمال.

ز. **مؤشرات المخاطر والأداء** – مؤشرات المخاطر والأداء هي مقاييس و/أو إحصاءات للمخاطر تُقدّم فهمًا دقيقًا لتعرض المنشأة المالية المرخصة للمخاطر. وتُقدّم هذه المؤشرات فهمًا أعمق لوضعية العمليات التشغيلية، والتي قد تُقدّم، بدورها، فهمًا أعمق لنقاط الضعف التشغيلية، والإخفاقات والخسائر المحتملة. وغالبًا ما تُرفق مؤشرات المخاطر والأداء بمؤشرات للتصعيد وذلك للتحذير عند اقتراب مستويات المخاطر من الحدود أو السقوف أو تجاوزها، من أجل وضع خطط للتخفيف من المخاطر.

توفر مقارنة المقاييس والتوجهات ذات الصلة على مر الزمن مقارنةً بالحدود أو السقوف المتفق عليها، معلومات قيمة لأغراض إدارة المخاطر وإعداد التقارير، وقد توفر معلومات إنذار مبكر حول أداء العمل وبيئة الضبط.

ح. **تحليل السيناريوهات** – يُعد تحليل السيناريوهات أسلوبًا لتحديد، وتحليل، وقياس مجموعة من السيناريوهات، بما في ذلك الأحداث منخفضة الاحتمالية وعالية الشدة، والتي قد تنجم عن بعضها خسائر فادحة متعلقة بالمخاطر التشغيلية. ويتضمن تحليل السيناريوهات، في الغالب، ورش عمل لخبراء متخصصين في الموضوع، بما في ذلك الإدارة العليا، وإدارة الأعمال، وكبار موظفي

staff and other functional areas such as compliance, human resources and IT risk management, to develop and analyse the drivers and range of consequences of potential events. Inputs to the scenario analysis would typically include relevant internal and external loss data, information from self-assessments, the control monitoring and assurance framework, forward-looking metrics, root-cause analyses and the process framework, where used. The scenario analysis process could be used to develop a range of consequences of potential events, including impact assessments for risk management purposes, supplementing other tools based on historical data or current risk assessments. It could also be integrated with disaster recovery and business continuity plans, for use within testing of Operational Resilience. Given the subjectivity of the scenario process, a robust governance framework and independent review are important to ensure the integrity and consistency of the process.

المخاطر التشغيلية، ومجالات وظيفية أخرى مثل الامتثال، والموارد البشرية، وإدارة مخاطر تقنية المعلومات، وذلك لتطوير وتحليل محركات الأحداث المحتملة ونطاق عواقبها. وغالبًا ما تتضمن مدخلات تحليل السيناريوهات بيانات الخسائر الداخلية والخارجية ذات الصلة، ومعلومات من التقييمات الذاتية، وإطار مراقبة الضوابط والتدقيق عليها، والمقاييس الاستشرافية، وتحليلات الأسباب الجذرية، وإطار العملية، حيثما يكون مستخدمًا. ويمكن استخدام عملية تحليل السيناريوهات لتطوير مجموعة من عواقب الأحداث المحتملة، بما في ذلك تقييمات تأثير لأغراض إدارة المخاطر، مكملةً لأدوات أخرى تستند إلى البيانات التاريخية أو تقييمات المخاطر الحالية. كما يمكن دمجها مع خطط التعافي من الكوارث واستمرارية الأعمال، لاستخدامها في اختبار المرونة التشغيلية. ونظرًا لأن عملية السيناريوهات ذاتية بطبيعتها، فإن وجود إطار حوكمة متين وفعال، ومراجعة مستقلة، أمران مهمان لضمان سلامة واتساق العملية.

- i. **Models** – LFIs may find it useful to quantify their exposure to Operational Risk by using the output of the risk assessment tools as inputs into a model that estimates Operational Risk exposure. The results of the model can be used in an economic capital process and can be allocated to business lines to link risk and return.

ط. **النماذج** – قد تجد المنشآت المالية المرخصة أنه من المفيد تحديد مدى تعرضها للمخاطر التشغيلية باستخدام مخرجات أدوات تقييم المخاطر كمدخلات في نموذج يُقدّر مدى تعرضها للمخاطر التشغيلية. يمكن استخدام نتائج النموذج في عملية رأس المال الاقتصادي، ويمكن تخصيصها لفروع الأعمال لربط المخاطر بالعائدات.

- j. **Benchmarking and comparative analysis** – Benchmarking and comparative analysis are comparisons of the outcomes of different risk measurement and management tools deployed within the LFI, as well as comparisons of metrics from the LFI to other firms in the industry. Such comparisons can be performed to enhance understanding of the LFI's Operational Risk profile. For example, comparing the frequency and severity of internal losses with self-assessments can help the LFI determine whether its self-assessment processes are functioning effectively. Scenario data can be compared to internal and external loss data to gain a better

ي. **القياس المقارن والتحليل المقارن** – القياس المقارن والتحليل المقارن هما مقارنات لنتائج مختلف أدوات قياس وإدارة المخاطر المستخدمة لدى المنشأة المالية المرخصة، بالإضافة إلى مقارنات بين مقاييس من المنشأة المالية المرخصة مع شركات أخرى في القطاع. يمكن إجراء هذه المقارنات لتعزيز فهم ملف المخاطر التشغيلية لدى المنشأة المالية المرخصة. على سبيل المثال، يمكن أن تساعد مقارنة وتيرة وشدة الخسائر الداخلية مع التقييمات الذاتية المنشأة المالية المرخصة في تحديد ما إذا كانت عمليات التقييم الذاتي الخاصة بها تعمل بفعالية. ويمكن مقارنة بيانات السيناريوهات ببيانات الخسائر الداخلية والخارجية للحصول على فهم أفضل لمدى تعرض المنشأة المالية المرخصة لأحداث مخاطر محتملة.

understanding of the severity of the LFI's exposure to potential risk events.

- k. **Audit findings** – while audit findings primarily focus on control weaknesses and vulnerabilities, they can also provide insight into inherent risk due to internal or external factors. LFIs must not solely rely on internal audit to identify Operational Risks.

ك. **نتائج التدقيق** – على الرغم من أن نتائج التدقيق تُركز بشكل أساسي على نقاط ضعف الضوابط وثغراتها، إلا أنها تُقدم أيضًا فهمًا أعمق للمخاطر الكامنة الناجمة عن عوامل داخلية أو خارجية. ويجب ألا تعتمد المنشآت المالية المرخصة على التدقيق الداخلي وحده لتحديد المخاطر التشغيلية.